

RELATÓRIO INDIVIDUAL PRELIMINAR

CEDAE - Companhia Estadual de Águas e Esgotos do Rio de Janeiro

1. Introdução

Este relatório apresenta os resultados preliminares da organização **CEDAE** relativos à Fiscalização TCE-RJ nº 18/2026, realizada pelo TCE-RJ entre fevereiro e junho de 2026 para avaliar o grau de adoção de práticas de governança e gestão de tecnologia da informação e comunicação pelas organizações jurisdicionadas.

O trabalho abrangeu órgãos e entidades de todos os poderes da Administração Pública Estadual e um conjunto de prefeituras municipais.

2. iGovTI 2026

A avaliação das organizações jurisdicionadas baseia-se no método de autoavaliação de controles (*Control Self-Assessment* – CSA), operacionalizado mediante questionário eletrônico. A ferramenta permitiu aos gestores declarar o nível de adoção das práticas de tecnologia da informação avaliadas e encaminhar a documentação probatória correspondente. As evidências anexadas e as justificativas apresentadas foram submetidas à análise de consistência por esta Equipe de Auditoria, servindo de subsídio para eventuais ajustes na pontuação declarada e para a identificação de inconformidades ou achados de auditoria.

O questionário do iGovTI 2026 foi estruturado com o objetivo de diagnosticar aspectos essenciais de governança e gestão de TIC, abrangendo segurança da informação, gestão de riscos, continuidade de negócios, serviços de tecnologia, contratações de TIC, estrutura e força de trabalho, desenvolvimento de soluções, gestão de projetos e temas emergentes, a exemplo do uso de inteligência artificial. Para além do diagnóstico situacional de cada organização, o instrumento serve como referencial metodológico para futuras ações de melhoria de gestão.

O iGovTI 2026 constitui um índice composto, mensurado em uma escala de 0 a 1. A quantificação do índice inicia-se com a conversão das respostas categóricas declaradas em coeficientes numéricos, conforme os critérios de valoração estabelecidos na Tabela 1.

Tabela 1 - Critérios de valoração das respostas qualitativas do questionário iGovTI 2026

Categoria de Resposta Declarada	Coefficiente Numérico
Não adota	0,00
Há decisão formal ou plano aprovado para adotá-lo	0,05
Adota em menor parte	0,15
Adota parcialmente	0,50

Categoria de Resposta Declarada	Coefficiente Numérico
Adota em maior parte ou totalmente	1,00

(Fonte: elaboração própria)

Nas questões que admitem itens de detalhamento, a pontuação da questão principal sofre deduções proporcionais à quantidade de itens não atendidos pela organização. Subsequentemente, os valores são consolidados por meio de agregação ponderada em uma estrutura hierárquica. O índice final é composto por dois blocos principais, conforme detalhado na Figura 1: **Governança de TIC (peso de 47,8%)**, formado por 4 questões de agregação direta; **Gestão de TIC (iGestTI) (peso de 52,2%)**, estruturado em 6 dimensões operacionais que consolidam 20 questões principais ponderadas.

Figura 1 - Composição do iGovTI 2026



(Fonte: elaboração própria)

Com base na pontuação consolidada do iGovTI 2026, a organização é classificada em um de quatro níveis de maturidade, cujos intervalos de pontuação estão definidos na Tabela 2 e representados graficamente na parte inferior da Figura 1.

Tabela 2 - Intervalos de pontuação para enquadramento nos níveis de maturidade

Nível de Maturidade	Intervalo do Índice (iGovTI)
Inexpressivo	$0,00 \leq \text{iGovTI} < 0,15$
Iniciando	$0,15 \leq \text{iGovTI} < 0,40$

Nível de Maturidade	Intervalo do Índice (iGovTI)
Intermediário	$0,40 \leq \text{iGovTI} < 0,70$
Aprimorado	$0,70 \leq \text{iGovTI} \leq 1,00$

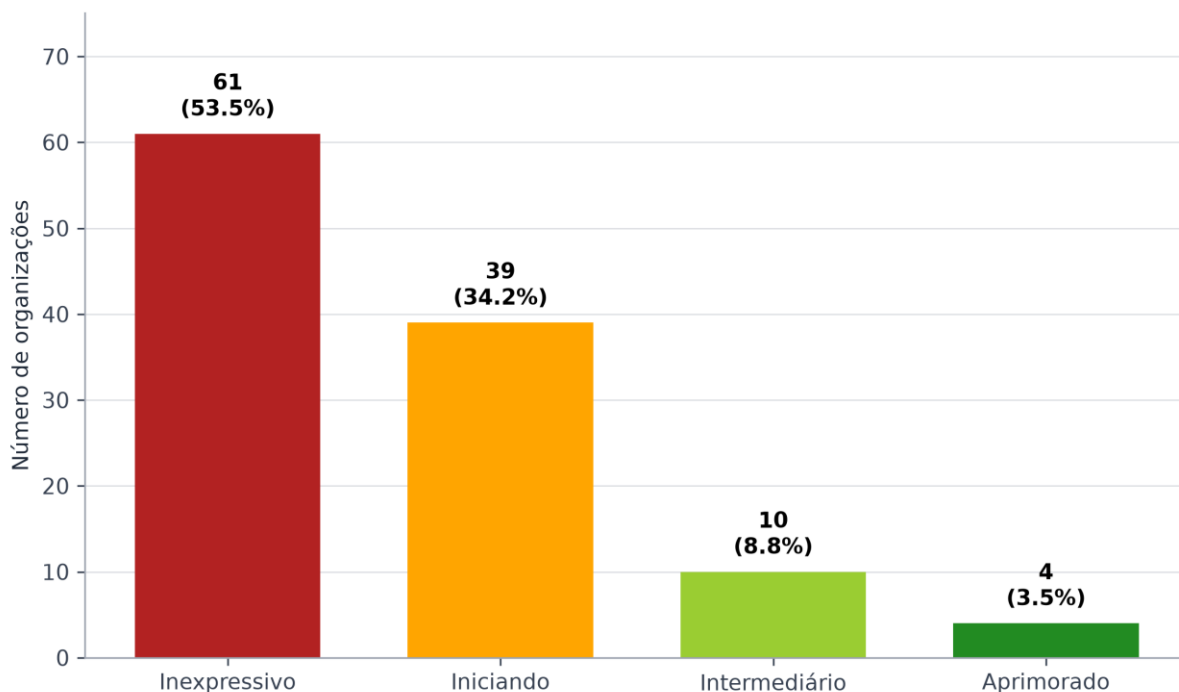
(Fonte: elaboração própria)

2.1. Cenário Geral

A análise consolidada apresentada nesta seção fundamenta-se nos resultados calculados para as 114 organizações que integram o universo amostral da fiscalização. A análise visa contextualizar o resultado individual da organização **CEDAE**, identificar padrões de maturidade, assimetrias entre governança e gestão e capacidades desenvolvidas no conjunto avaliado.

A distribuição por nível de maturidade, apresentada na Figura 2, evidencia concentração nos estágios iniciais. Das 114 organizações, 61 (53,5%) foram classificadas no nível **Inexpressivo** e 39 (34,2%) no nível **Iniciando**. Assim, 100 organizações (87,7%) obtiveram resultado inferior a 0,40. Somente 10 organizações (8,8%) alcançaram o nível **Intermediário** e 4 (3,5%) o nível **Aprimorado**.

Figura 2 - Distribuição das organizações por nível de maturidade do iGovTI 2026



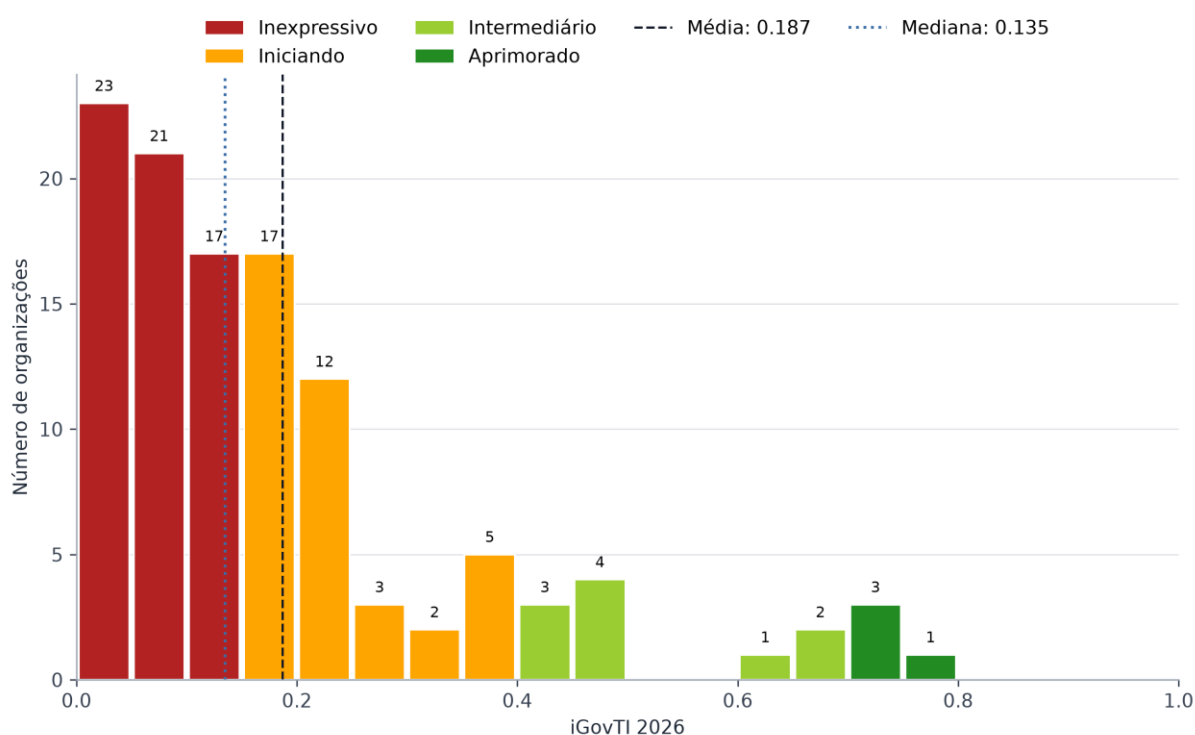
(Fonte: elaboração própria)

O iGovTI apresentou média de 0,187 e mediana de 0,135. O primeiro quartil foi 0,066 e o terceiro quartil, 0,235, o que evidencia a concentração de 50% das organizações avaliadas nesse intervalo, bem como a permanência de pelo menos 75% das entidades

abaixo do nível Intermediário. A divergência positiva entre a média e a mediana, combinada com o valor máximo de 0,777 e com apenas 4 organizações no nível Aprimorado, caracteriza uma distribuição com assimetria à direita (positiva): um grupo reduzido de resultados elevados desloca a média para cima, sem alterar o quadro predominante de baixa maturidade. 5 organizações apresentaram valor igual a zero no índice calculado.

A distribuição contínua da Figura 3 complementa a classificação por faixas e permite observar a concentração dos resultados, os limites de maturidade e a distância entre a mediana e os valores mais elevados.

Figura 3 - Distribuição contínua dos resultados do iGovTI 2026



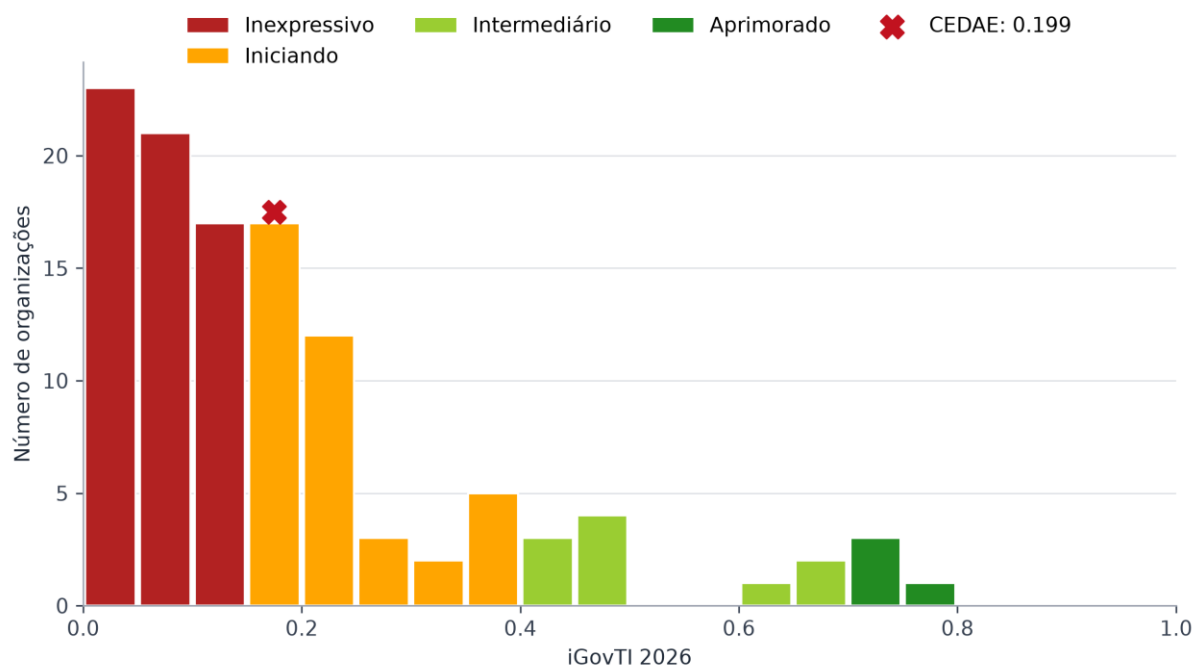
(Fonte: elaboração própria)

A posição específica da organização **CEDAE** nessa distribuição pode ser observada na Figura 4. Diferenças marginais de pontuação entre organizações adjacentes no ranking devem ser interpretadas com cautela analítica, visto que o modelo matemático de composição do índice não pressupõe estimativa de erro amostral e que os resultados estão sujeitos à qualidade e à fidedignidade declaratória do jurisdicionado.

2.2. Cenário atual - CEDAE

Apresentado o panorama geral do universo fiscalizado, esta subseção detalha o desempenho específico da organização jurisdicionada. A organização **CEDAE** obteve o valor **0,1992** para o **iGovTI 2026**, correspondente ao nível **Iniciando** de maturidade.

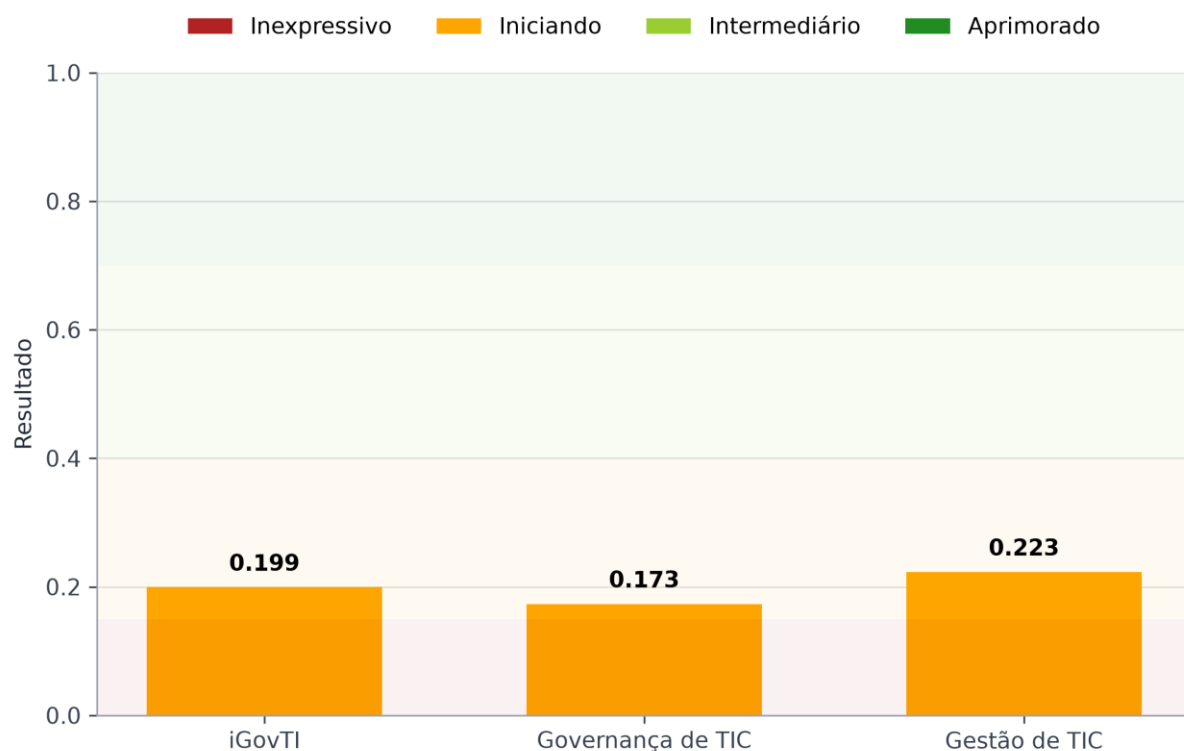
Figura 4 - Distribuição dos resultados do iGovTI 2026 e posição da organização CEDAE



(Fonte: elaboração própria)

A Figura 5 apresenta a composição do resultado da organização **CEDAE** entre governança e gestão de TIC.

Figura 5 - Resultado da organização CEDAE por componentes do iGovTI 2026



(Fonte: elaboração própria)

Tabela 3 - Resultado sintético do iGovTI 2026 da organização CEDAE

Componente	Peso no iGovTI 2026	Valor
Governança de TIC	0,4777	0,1733
Gestão de TIC	0,5223	0,2230
iGovTI 2026	1,0000	0,1992

(Fonte: elaboração própria)

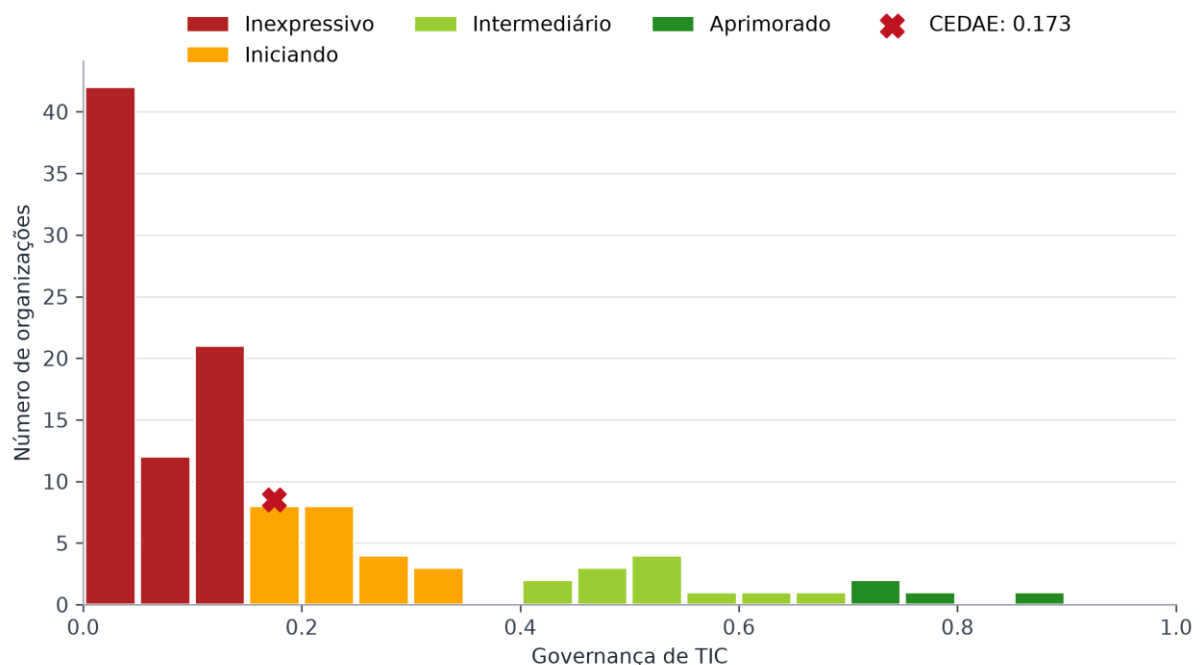
2.2.1. Governança de TIC

A governança de TIC avalia a capacidade da alta administração de orientar, dirigir, monitorar e controlar o uso da tecnologia da informação, de modo alinhado aos objetivos institucionais, aos riscos relevantes e às necessidades das áreas finalísticas e administrativas.

No iGovTI 2026, a dimensão de governança consolida práticas relacionadas ao modelo de gestão de TIC, à atuação de comitês ou instâncias equivalentes, no monitoramento do desempenho, à participação da alta administração e ao alinhamento entre decisões de TIC, estratégia organizacional, orçamento, riscos e valor público.

A organização **CEDAE** obteve o **valor 0,1733 no componente Governança de TIC**.

Figura 6 - Resultado do componente Governança de TIC da organização CEDAE



(Fonte: elaboração própria)

2.2.2. Gestão de TIC

A gestão de TIC avalia a capacidade da organização de planejar, executar, monitorar e aperfeiçoar processos, serviços, controles, recursos e contratações de tecnologia da informação, de forma compatível com suas necessidades institucionais.

No iGovTI 2026, o componente **Gestão de TIC (iGestTI)** consolida seis dimensões operacionais: planejamento de TIC, gestão de serviços de TIC, gestão de riscos de TI e segurança da informação, estrutura de segurança da informação, processos de segurança da informação e gestão de soluções de TIC.

A organização **CEDAE** obteve o valor **0,2230** no componente **Gestão de TIC**.

Figura 7 - Resultado do componente Gestão de TIC da organização CEDAE

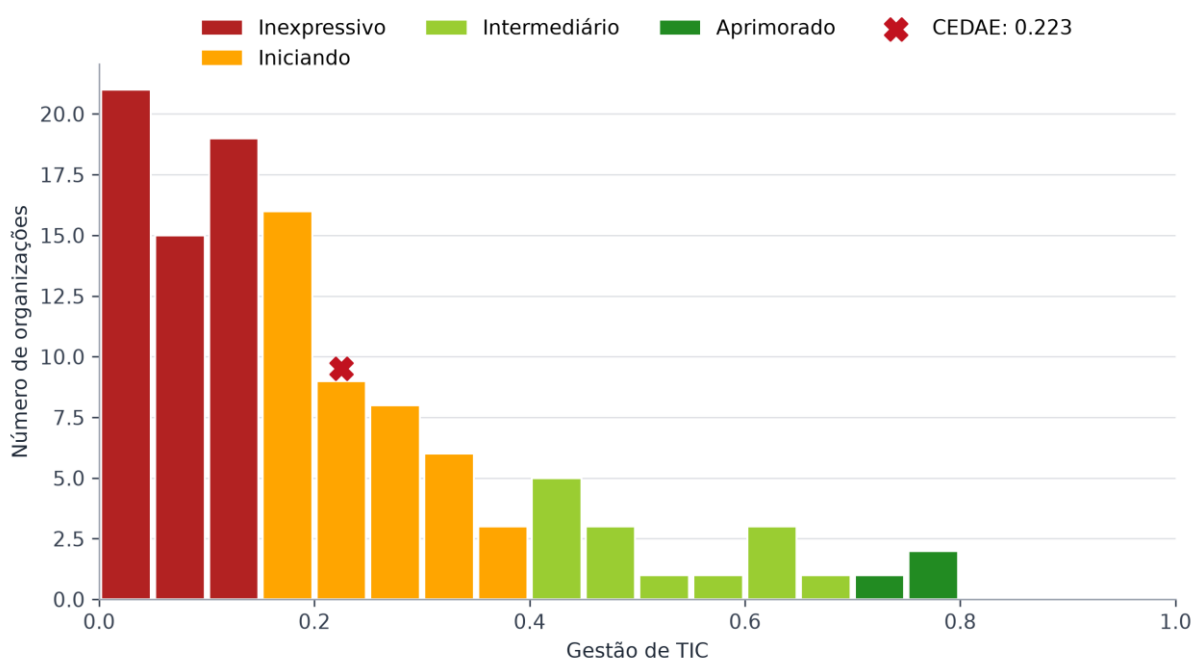


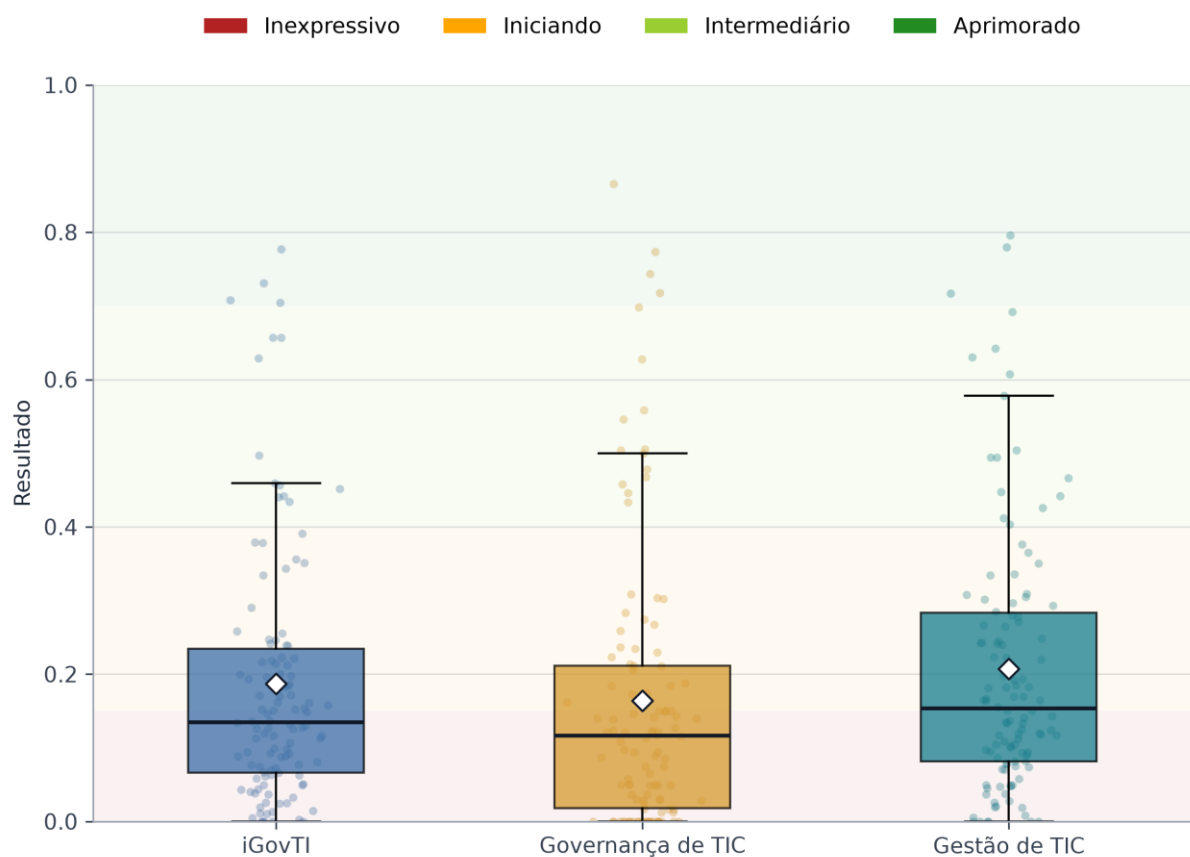
Tabela 4 - Estatísticas descritivas do iGovTI 2026 e de seus componentes principais

Indicador	1º quartil	Mediana	3º quartil	Organizações com valor >= 0,40	Valor CEDAE
iGovTI	0,187	0,135	0,235	14 (12,3%)	0,1992
Governança de TIC	0,164	0,117	0,211	16 (14,0%)	0,1733
Gestão de TIC	0,208	0,153	0,283	17 (14,9%)	0,2230

(Fonte: elaboração própria)

A Figura 8 permite comparar a dispersão dos três indicadores. O resultado em Gestão de TIC superou o de Governança de TIC em 76 organizações (66,7%); o movimento inverso ocorreu em 33 (28,9%); e houve igualdade em 5 (4,4%). O padrão indica que, para a maior parte das organizações, as capacidades operacionais de gestão se situaram em patamar superior ao dos mecanismos de direção, monitoramento e controle exercidos pela alta administração. Essa diferença, contudo, não elimina a baixa maturidade da gestão: 97 organizações (85,1%) também obtiveram resultado em Gestão de TIC inferior a 0,40.

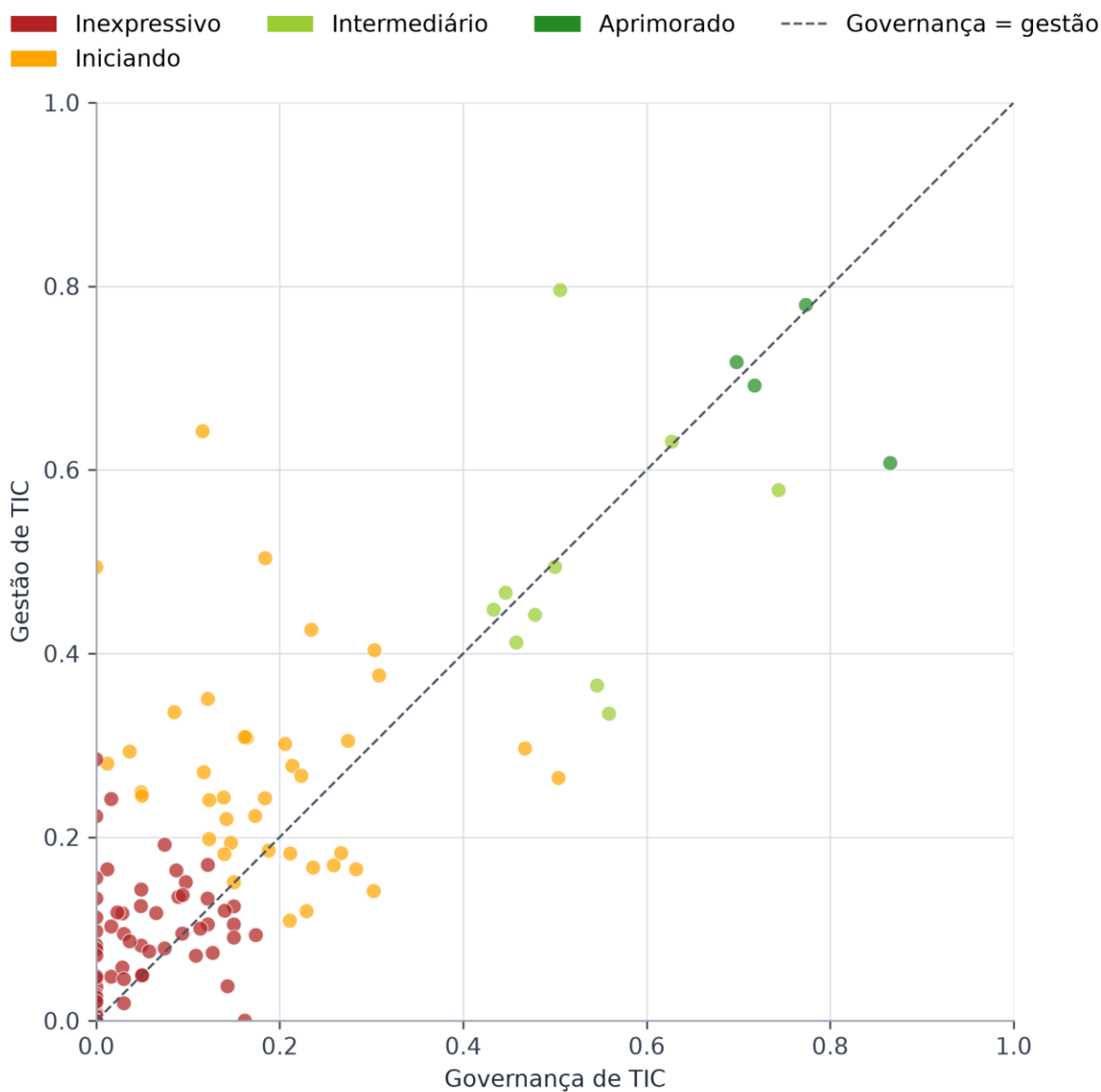
Figura 8 - Distribuição do iGovTI 2026 e dos componentes Governança de TIC e Gestão de TIC



(Fonte: elaboração própria)

A Figura 9 mostra a posição simultânea das organizações nos dois componentes. Pontos abaixo da diagonal representam resultado de gestão superior ao de governança; pontos acima da diagonal representam a situação inversa.

Figura 9 - Relação entre os resultados de governança e gestão de TIC



(Fonte: elaboração própria)

No caso da organização **CEDAE**, os resultados de Governança de TIC e Gestão de TIC apresentaram valores próximos, sem indicar assimetria relevante entre os componentes principais. A análise deve considerar o nível de maturidade alcançado, a distribuição dos resultados nas dimensões avaliadas e as fragilidades específicas evidenciadas nos achados de auditoria.

2.4. Dimensões da gestão de TIC

A decomposição da Gestão de TIC revela diferenças relevantes entre as seis dimensões avaliadas. Conforme a Tabela 5, **Planejamento de TIC** apresentou a maior média (0,293) e a maior mediana (0,157). A dimensão com maior média também figurou como a de maior resultado em 50 organizações (43,9%), considerados os empates. Esse padrão indica que algumas capacidades se encontram mais disseminadas do que outras no conjunto fiscalizado.

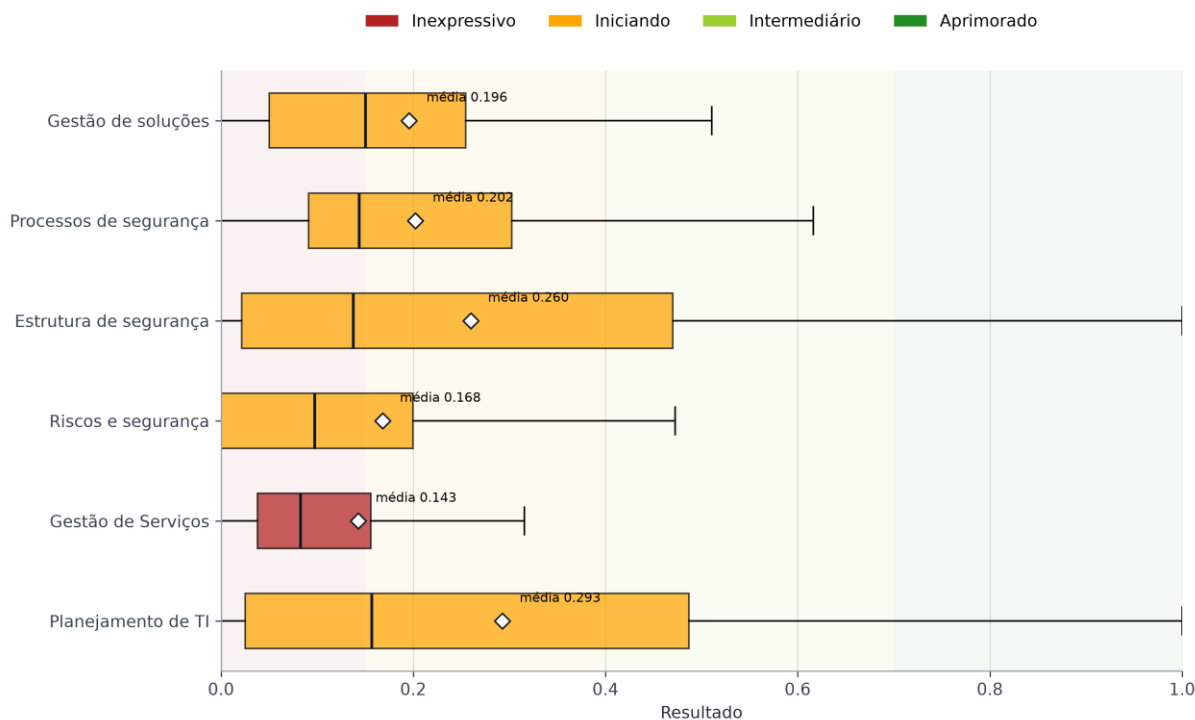
Tabela 5 - Estatísticas descritivas das dimensões de Gestão de TIC

Dimensão	Média	Mediana	Resultados iguais a zero	Organizações com valor inferior a 0,40	Valor CEDAE
Planejamento de TIC	0,293	0,157	21 (18,4%)	80 (70,2%)	0,2818
Gestão de Serviços de TIC	0,143	0,083	20 (17,5%)	102 (89,5%)	0,1162
Gestão de Riscos de TI e Segurança da Informação	0,168	0,097	32 (28,1%)	97 (85,1%)	0,1266
Estrutura de Segurança da Informação	0,260	0,137	25 (21,9%)	83 (72,8%)	0,3086
Processos de Segurança da Informação	0,202	0,144	10 (8,8%)	95 (83,3%)	0,3121
Gestão de Soluções de TIC	0,196	0,150	26 (22,8%)	101 (88,6%)	0,2024

(Fonte: elaboração própria)

A distribuição completa das seis dimensões é apresentada na Figura 10, incluindo medianas, intervalos interquartis e médias.

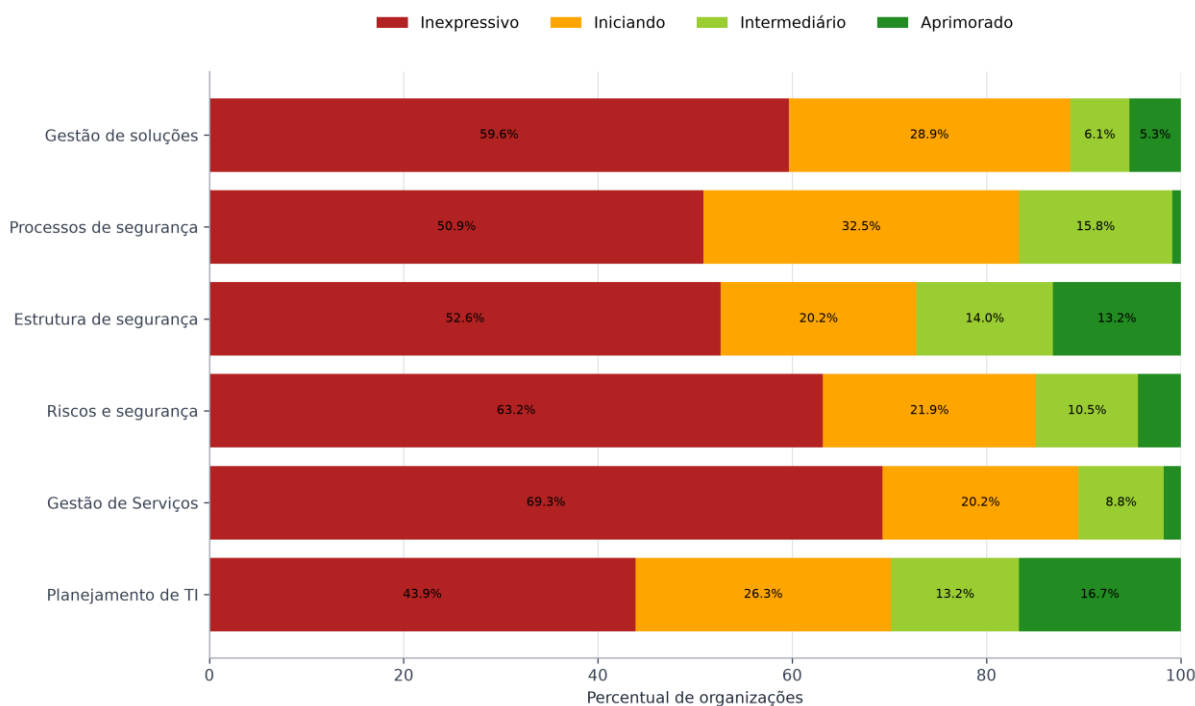
Figura 10 - Distribuição dos resultados das seis dimensões de Gestão de TIC



(Fonte: elaboração própria)

A Figura 11 explicita a composição de cada dimensão por nível de maturidade e permite verificar em quais capacidades se concentram as organizações nos estágios iniciais.

Figura 11 - Distribuição dos níveis de maturidade das organizações nas dimensões de Gestão de TIC



(Fonte: elaboração própria)

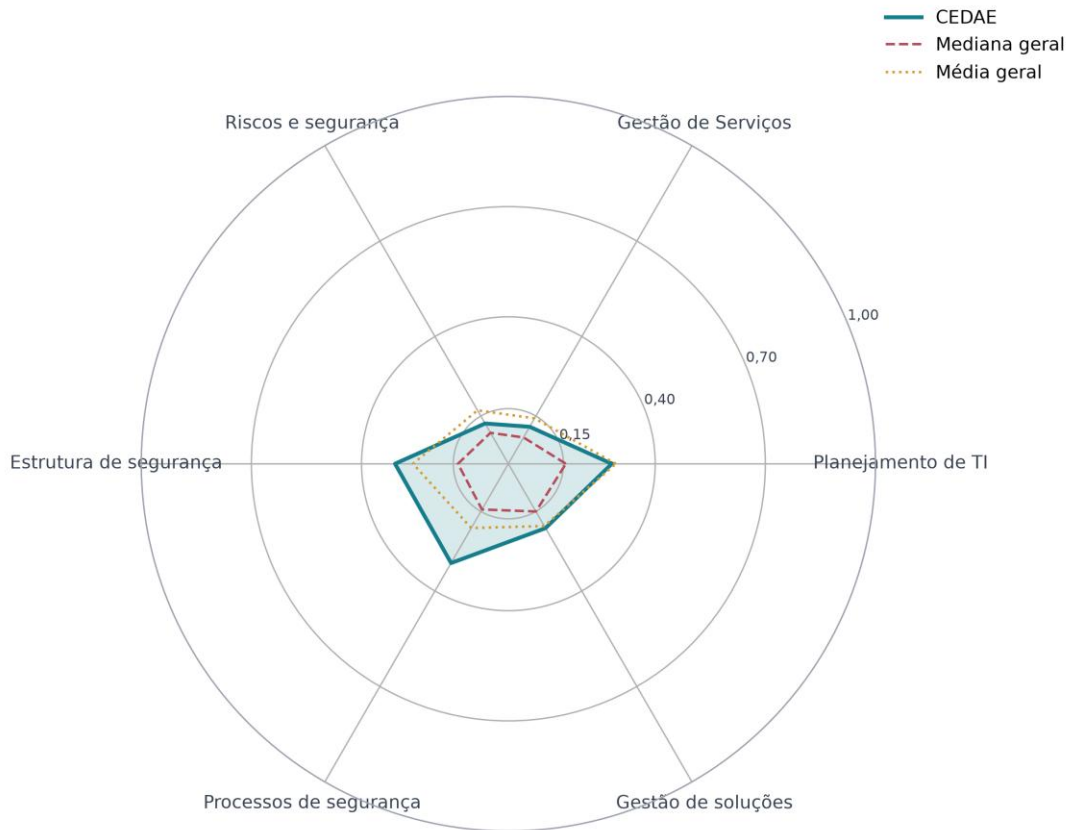
As menores médias foram observadas em **Gestão de serviços de TIC** (0,143) e **Riscos de TI e de segurança da informação** (0,168). A primeira registrou valor inferior a 0,40 em 102 organizações (89,5%) e apareceu entre as dimensões de menor resultado de 37 organizações (32,5%), considerados os empates. Para a segunda, esses quantitativos foram, respectivamente, 97 (85,1%) e 39 (34,2%). O quadro indica que a formalização do planejamento, quando existente, frequentemente não é acompanhada, na mesma intensidade, pelas demais capacidades operacionais e de segurança.

A dimensão Estrutura de Segurança da Informação apresentou média de 0,260 e mediana de 0,137. Essa diferença, associada à ampla dispersão observada na Figura 10, evidencia heterogeneidade: um grupo de organizações possui estruturas de segurança mais consolidadas, enquanto parcela expressiva permanece próxima dos níveis inferiores. A dimensão Processos de Segurança da Informação mostrou mediana superior à de Estrutura de Segurança da Informação, mas 83,3% das organizações ainda permaneceram abaixo de 0,40, o que recomenda examinar separadamente a existência da estrutura formal e a execução contínua dos processos de segurança.

2.5. Leitura integrada do resultado individual

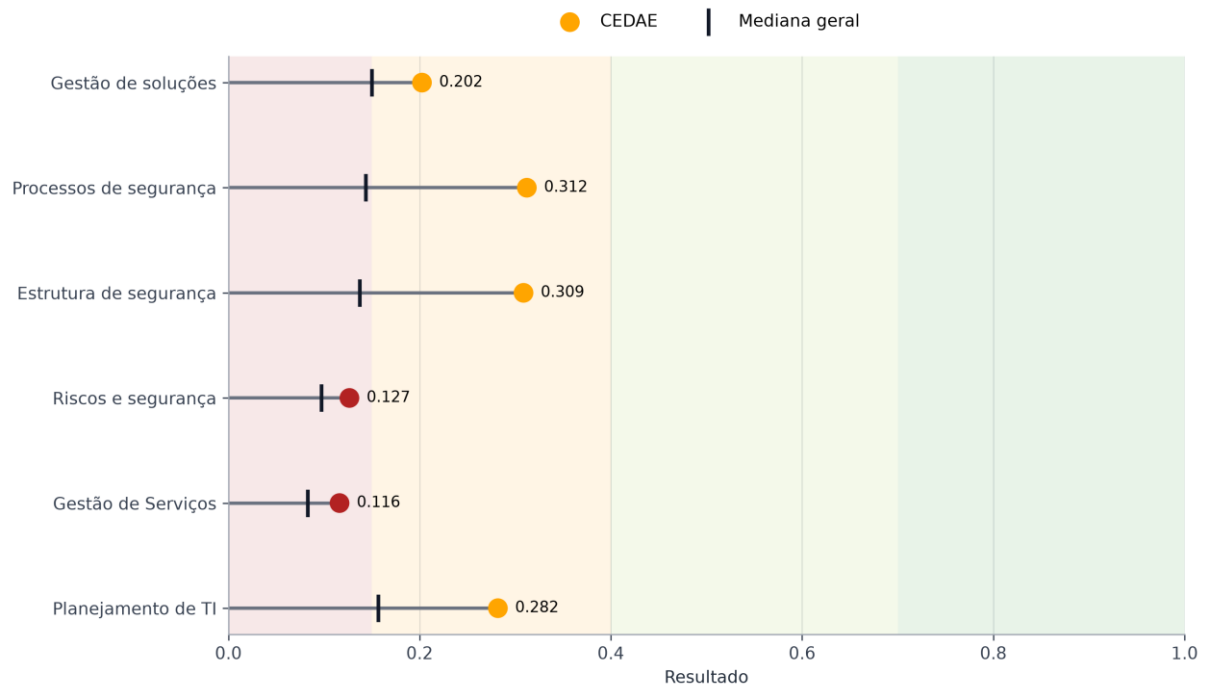
A Figura 12 apresenta o perfil da organização **CEDAE** nas seis dimensões de gestão e o compara com as medianas observadas nas 114 organizações. A comparação linear da Figura 13 permite identificar com maior precisão a distância entre o resultado individual e a mediana geral em cada dimensão.

Figura 12 - Perfil da organização nas dimensões de Gestão de TIC em comparação com os demais



(Fonte: elaboração própria)

Figura 13 - Comparação do resultado individual e da mediana nas dimensões de Gestão de TIC



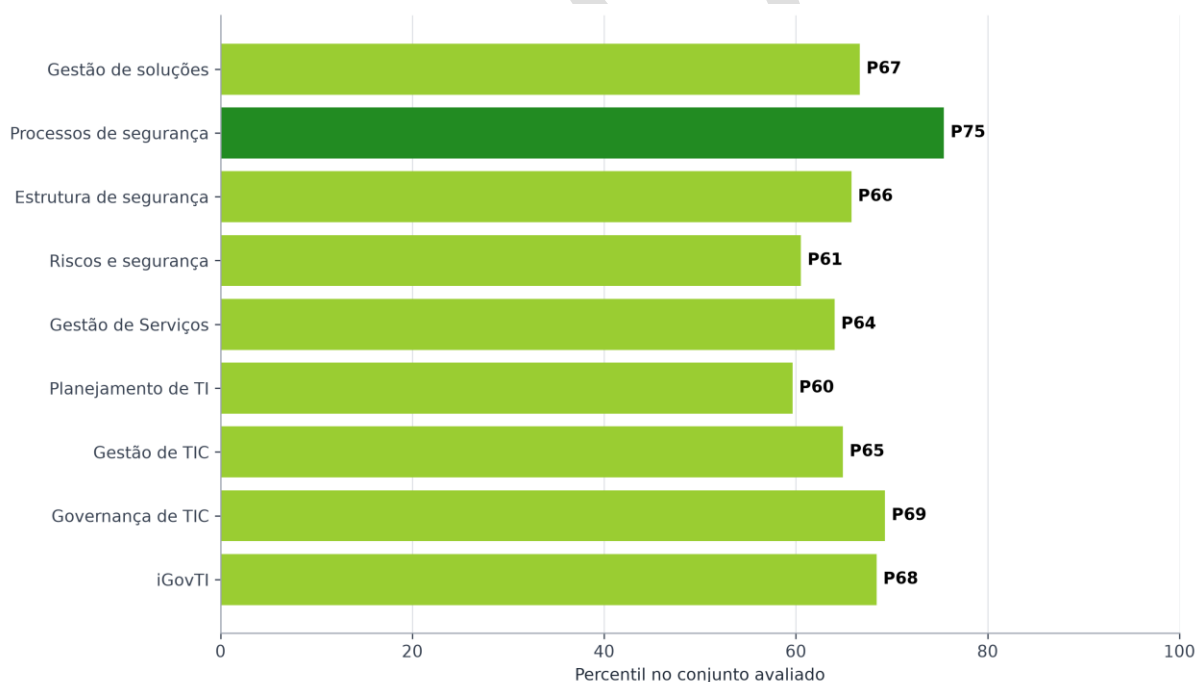
(Fonte: elaboração própria)

O resultado em Planejamento de TIC (0,2818) situa-se nos níveis iniciais de maturidade. Esse resultado indica oportunidade de priorizar a estruturação do planejamento de TIC, de modo a fortalecer a definição de diretrizes, prioridades, responsáveis, recursos, contratações e mecanismos de acompanhamento.

A Figura 14 compara a posição da organização **CEDAE** com as demais organizações avaliadas em cada indicador. A letra “P” indica a posição relativa (percentil) no conjunto: **P50** representa posição próxima ao centro da distribuição; **P90** indica que a organização obteve resultado igual ou superior ao de aproximadamente 90% das organizações avaliadas; e **P20** indica que apenas cerca de 20% das organizações tiveram resultado igual ou inferior. Assim, quanto maior o valor de “P”, melhor é a posição relativa da organização naquele indicador.

Essa comparação deve ser interpretada com cautela. A posição relativa não substitui o valor do índice, o nível de maturidade nem a análise de conformidade realizada nos achados de auditoria. Ela serve apenas para indicar se o resultado da organização ficou relativamente abaixo, próximo ou acima do conjunto avaliado.

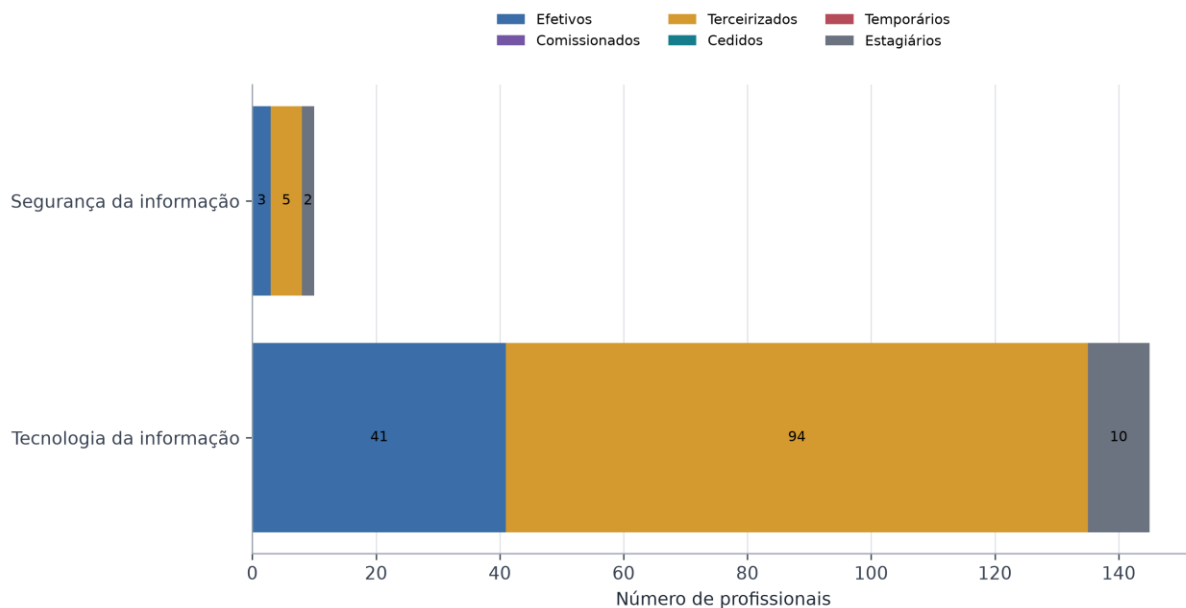
Figura 14 - Comparação da posição relativa da organização CEDAE nos indicadores avaliados



(Fonte: elaboração própria)

A composição declarada da força de trabalho de TIC e de segurança da informação é apresentada na Figura 15. Os quantitativos não compõem o índice e não medem, isoladamente, suficiência de pessoal; sua avaliação depende do porte, da complexidade, da terceirização, dos serviços mantidos e dos riscos da organização.

Figura 15 - Composição declarada da força de trabalho de TIC e segurança da informação



(Fonte: elaboração própria)

A priorização de melhorias não deve buscar apenas a elevação numérica do índice. Recomenda-se concentrar esforços nas capacidades com menor resultado que, simultaneamente, estejam associadas a riscos relevantes, serviços críticos, obrigações normativas e necessidades institucionais da organização **CEDAE**.

3. Resultados da Auditoria

No âmbito desta fiscalização, foram definidas questões de auditoria para orientar a avaliação da governança e da gestão de TIC. Para fins deste relatório individual preliminar, os possíveis achados decorrem da verificação das Questões 1 a 6.

Tabela 7 - Questões de auditoria com avaliação individual preliminar

Questão	Tema	Síntese do objeto avaliado
Q1	Estrutura de TIC	Existência formal, atribuições e posicionamento organizacional da área, unidade, setor ou função responsável pela TIC.
Q2	Governança e comitê de TIC	Modelo de governança e gestão de TIC, objetivos, indicadores, metas e atuação do comitê ou instância equivalente.
Q3	Planejamento de TIC	Processo de planejamento, plano de TIC vigente, aprovação, alinhamento institucional, integração orçamentária e acompanhamento.
Q4	Capacidade institucional de TIC e segurança da informação	Força de trabalho, perfis, competências, funções, vínculos e capacidade interna para sustentar a TIC e a segurança da informação.
Q5	Gestão de serviços de TIC	Catálogo de serviços, níveis mínimos de serviço, inventário de ativos, gestão de configuração e tratamento de incidentes.
Q6	Contratações de TIC	Fluxo de contratação, papéis, modelos orientativos, aprovação técnica, alinhamento ao planejamento e equipe de planejamento.

(Fonte: elaboração própria)

Os achados de auditoria decorrem da avaliação preliminar das respostas da organização **CEDAE** ao questionário iGovTI 2026 e da correspondente análise de consistência documental realizada por esta Equipe de Auditoria. O trabalho consistiu no confronto sistemático entre as práticas de governança e gestão autodeclaradas pela organização e as evidências comprobatórias efetivamente encaminhadas, à luz da legislação aplicável e de padrões técnicos de referência internacional.

O presente relatório individual adota uma estrutura analítica de apresentação voltada a conferir clareza, rastreabilidade e utilidade diagnóstica às constatações. Desse modo, cada achado de auditoria está estruturado a partir dos seguintes elementos fundamentais:

- **Critérios:** as referências normativas, legais, regulamentares ou de boas práticas de gestão (como os objetivos do COBIT 2019 e normas da série ABNT NBR ISO/IEC) que estabelecem o padrão esperado de conformidade;
- **Evidências:** a relação das informações e dos documentos anexados pela organização que serviram de suporte factual para as constatações;

- **Situação Encontrada:** a descrição detalhada da realidade operacional e documental identificada no jurisdicionado, destacando-se as fragilidades e lacunas específicas em relação aos critérios adotados;
- **Conclusão da Equipe de Auditoria:** a análise técnica e o juízo profissional formulado a partir da correlação entre a situação factual e as regras de controle estabelecidas no mapa de verificação;
- **Propostas de Encaminhamento:** as recomendações preliminares propostas com o intuito de orientar a organização na correção de fragilidades e no aprimoramento de suas capacidades de governança e gestão de TIC.

Cumprе ressaltar o caráter preliminar das constatações ora apresentadas. A disponibilização deste relatório visa subsidiar a fase de comentários do gestor, permitindo à organização apresentar esclarecimentos adicionais, correções de fato ou novas informações que possam orientar a manifestação final desta Corte de Contas.

Achado 1 – Estrutura de TIC insuficiente para coordenar, gerir e sustentar a tecnologia da informação.

Critérios

- COBIT 2019, APO01.06 - Aprimorar o posicionamento da função de TI: posicionar a função de tecnologia de modo compatível com sua relevância estratégica, responsabilidades e necessidade de interação com a alta administração;
- ABNT NBR ISO/IEC 38500:2025, item 5.6.1 - Governança efetiva de TI: responsabilização clara, estrutura adequada de tomada de decisão e direção organizacional compatível com o uso atual e futuro da tecnologia;
- Portaria SGD/ME nº 778/2019, art. 4º, § 1º - Como referência de boa prática, a área de TIC deve, preferencialmente, estar vinculada à alta administração para apoiá-la na tomada de decisões e no alcance dos objetivos estratégicos.

Evidências

- **E1:** Resposta “b) Centralizada Terceirizada: Há uma área de TI centralizada e formal que faz a gestão, mas a execução operacional/técnica é predominantemente terceirizada (ex: fábricas de software, service desk).” ao item 0101 do Questionário, para verificar qual alternativa melhor descreve a formalização e o modelo de operação predominante da Tecnologia da Informação (TI) na organização;
- **E2:** Resposta “c) a área de TI está subordinada a área administrativa, financeira ou área meio equivalente” ao item 0102 do Questionário, para verificar como a área de tecnologia da informação está posicionada na estrutura hierárquica da organização.

Situação encontrada

A existência de estrutura formal de TIC é requisito básico para que a organização disponha de unidade, setor ou função institucionalmente reconhecida para planejar, coordenar, gerir, executar, monitorar e controlar o uso da tecnologia da informação. Sob a perspectiva de governança de TIC, essa estruturação envolve três dimensões complementares: formalização da área ou função de TIC, definição de atribuições e competências essenciais e posicionamento organizacional adequado para participar das decisões estratégicas, orçamentárias, contratuais e de gestão de riscos.

Os critérios de boas práticas indicam que a organização deve estabelecer estruturas organizacionais apropriadas, comunicar papéis e responsabilidades de maneira clara, definir políticas e procedimentos de gestão de TIC e posicionar a função de tecnologia de modo

compatível com sua relevância estratégica¹. Esses requisitos convergem com as diretrizes da ABNT NBR ISO/IEC 38500:2025, que orienta sobre a necessidade de responsabilização clara e de estruturas adequadas de tomada de decisão para a governança efetiva de TI², e com a referência de vinculação preferencial da área de TIC à alta administração prevista no art. 4º, § 1º, da Portaria SGD/ME nº 778/2019.

Com base na análise das respostas aos itens 0101, 0102 e 0103 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de governança. A Equipe de Auditoria identificou as seguintes deficiências na estrutura de TIC da organização:

- **Posicionamento organizacional:** o posicionamento informado não demonstrou compatibilidade suficiente com a relevância e as responsabilidades da função de TIC, em desacordo com o critério de aprimoramento do posicionamento da função de TI (COBIT 2019, APO01.06 e ABNT NBR ISO/IEC 38500:2025, item 5.6.1) e com a referência da Portaria SGD/ME nº 778/2019 (art. 4º, § 1º), o que pode reduzir a capacidade de influência institucional da TIC e comprometer sua participação em decisões estratégicas, orçamentárias, contratuais e de gestão de riscos.

Essa situação ensejou o presente achado e será detalhada na subseção seguinte.

Posicionamento organizacional da área de TIC

O posicionamento organizacional da área de TIC deve ser compatível com suas responsabilidades institucionais e com a dependência da organização em relação à tecnologia da informação. Não se trata de impor modelo único de estrutura, mas de assegurar que a função de TIC tenha capacidade de interação adequada com as instâncias decisórias responsáveis por estratégia, orçamento, contratações, riscos e prestação de serviços.

O COBIT 2019, no objetivo APO01.06, orienta o aprimoramento do posicionamento da função de TI para que a tecnologia seja tratada de modo compatível com sua relevância estratégica e com a necessidade de interação com a alta administração. A ABNT NBR ISO/IEC 38500:2025 reforça a necessidade de estrutura adequada de tomada de decisão para o uso atual e futuro da tecnologia. Como referência complementar de boa prática, o art. 4º, § 1º, da Portaria SGD/ME nº 778/2019 estabelece que a área de TIC deve, preferencialmente, estar vinculada à alta administração, com o intuito de apoiá-la na tomada de decisões e no alcance dos objetivos estratégicos.

¹ No domínio APO01 do COBIT 2019, a gestão da estrutura organizacional, de papéis, responsabilidades, políticas e posicionamento da função de TI é tratada como condição para que a tecnologia apoie os objetivos de governança e gestão da organização.

² A ABNT NBR ISO/IEC 38500:2025 orienta que a governança efetiva de TI pressupõe responsabilidades claras, estrutura adequada de decisão e direção organizacional compatível com o uso atual e futuro da tecnologia.

Um posicionamento organizacional incompatível com a relevância e as responsabilidades da TIC acarreta o risco de baixa capacidade de influência institucional. Essa fragilidade compromete a participação da área em decisões estratégicas, orçamentárias, contratuais e de gestão de riscos, além de dificultar a priorização de iniciativas e a articulação com as áreas de negócio.

No âmbito da fiscalização, o posicionamento adequado deve ser demonstrado por organograma institucional, regimento interno ou documento equivalente, de modo que seja possível verificar a vinculação da área de TIC e sua compatibilidade com as responsabilidades que lhe foram atribuídas.

Da análise das respostas aos itens 0101 e 0102 e da documentação apresentada, o posicionamento organizacional da área de TIC não se mostrou suficientemente compatível com a relevância e as responsabilidades da função de tecnologia da informação, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- Item 0101: a organização informou possuir área ou modelo de operação de TI, o que levou à análise do seu posicionamento organizacional (E1);
- Item 0102: o posicionamento hierárquico informado pela organização não demonstrou compatibilidade suficiente com a relevância institucional, as responsabilidades e a necessidade de interação da TIC com a alta administração (E2).

Conclusão

As fragilidades identificadas na estrutura de TIC reduzem a segurança de que a organização disponha de condições institucionais suficientes para coordenar, gerir e sustentar a tecnologia da informação de forma alinhada às necessidades institucionais.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos da estrutura de TIC efetivamente apontados neste achado, observados os critérios aplicáveis de governança e gestão previstos no COBIT 2019 e na ABNT NBR ISO/IEC 38500:2025, bem como a diretriz de posicionamento organizacional constante do art. 4º, § 1º, da Portaria SGD/ME nº 778/2019. ### Propostas de Encaminhamento

- **Comunicação com Recomendação** para que avalie e ajuste o posicionamento organizacional da área de TIC, atentando-se, minimamente, em assegurar interlocução adequada com a alta administração e participação nas decisões estratégicas, orçamentárias, contratuais e de gestão de riscos relacionadas à tecnologia da informação.

Achado 2 – Governança de TIC insuficiente para avaliar, dirigir e monitorar a tecnologia da informação.

CrITÉRIOS

- COBIT 2019, EDM01.02 - Dirigir o sistema de governança: orientar estruturas, princípios, processos e práticas de governança para assegurar que a TI apoie os objetivos organizacionais;
- COBIT 2019, MEA01.04 - Avaliar o desempenho: monitorar e avaliar periodicamente o desempenho e a conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas;
- Decreto nº 12.198/2024, art. 5º - Instituição do CGD, colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais nos órgãos e entidades da administração pública federal direta, autárquica e fundacional;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.1: necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes, responsabilidade de alinhar as ações de TI aos objetivos institucionais, priorizar investimentos e monitorar o desempenho da TI com base em indicadores e metas;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TI.

Evidências

- **E1:** Resposta negativa ao detalhamento a) do item 1002 do Questionário, para verificar se rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas;
- **E2:** Resposta negativa ao detalhamento e) do item 1001 do Questionário, para verificar se a organização dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização.

Situação encontrada

A governança de TIC compreende o conjunto de estruturas, papéis, responsabilidades, diretrizes e mecanismos de acompanhamento por meio dos quais a alta administração avalia, dirige e monitora o uso da tecnologia da informação. Sua finalidade é assegurar que os recursos de TIC apoiem os objetivos institucionais, sejam priorizados de forma transparente e tenham desempenho acompanhado com base em critérios objetivos.

Para que a governança de TIC esteja estruturada, a alta administração deve estabelecer modelo básico de governança e gestão de TIC, com papéis, responsabilidades, objetivos, indicadores e metas claras, além de assegurar a existência e o funcionamento regular de um Comitê de TIC ou instância colegiada equivalente.

Os critérios de boas práticas orientam que a organização deve dirigir o sistema de governança, monitorar o desempenho e a conformidade da TIC, definir papéis e responsabilidades e instituir instância colegiada capaz de alinhar ações de TIC aos objetivos institucionais, priorizar investimentos e acompanhar o desempenho com base em indicadores e metas³. Esses requisitos convergem com a necessidade de instância colegiada de governança digital, conforme diretriz do Decreto nº 12.198/2024⁴, e com as deliberações do Acórdão TCE-RJ 44.490/2024-PLEN⁵.

Com base na análise das respostas aos itens 1001 e 1002 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de governança. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Modelo básico de governança e gestão de TIC:** a ausência ou insuficiência de modelo formalizado não demonstra aderência aos critérios de direção do sistema de governança e avaliação de desempenho (COBIT 2019, EDM01.02/MEA01.04) e ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), gerando baixa clareza sobre papéis, responsabilidades, objetivos, indicadores e metas da TIC.
- **Instituição do Comitê de TIC:** a não instituição formal não se alinha ao Acórdão TCE-RJ 44.490/2024-PLEN (item II.1), ao COBIT 2019 (APO01.05) e à diretriz de referência do Decreto nº 12.198/2024 (art. 5º), dificultando a existência de instância colegiada para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Modelo básico de governança e gestão de TIC

O modelo básico de governança e gestão de TIC deve explicitar como a alta administração orienta, acompanha e responsabiliza a atuação da tecnologia da informação.

³ No COBIT 2019, o sistema de governança deve ser dirigido por estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais, com papéis e responsabilidades definidos e desempenho periodicamente monitorado.

⁴ O Decreto nº 12.198/2024 disciplina, no âmbito federal, o Comitê de Governança Digital como colegiado responsável por diretrizes e estratégias sobre o uso de recursos digitais, servindo como referência normativa para a estruturação de instâncias colegiadas de governança digital.

⁵ O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, registra a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes e atribuições de alinhamento, priorização e monitoramento.

Esse modelo deve conter, ao menos, diretrizes, papéis, responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico.

O COBIT 2019, no objetivo EDM01.02, orienta a direção do sistema de governança por meio de estruturas, princípios, processos e práticas que assegurem que a TI apoie os objetivos organizacionais. Em complemento, o objetivo MEA01.04 trata do monitoramento e da avaliação periódica do desempenho e da conformidade da TI em relação a objetivos, indicadores, metas e expectativas das partes interessadas.

A existência e a suficiência desse modelo devem ser demonstradas por políticas, diretrizes, definição de papéis e responsabilidades, objetivos, indicadores, metas, relatórios de acompanhamento, medições de desempenho ou instrumentos equivalentes.

Da análise das respostas aos itens 1001 e 1002 e da documentação apresentada, verificou-se que o modelo básico de governança e gestão de TIC não se mostrou suficientemente estruturado quanto a papéis, responsabilidades, objetivos, indicadores, metas ou forma de acompanhamento periódico, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 1002, não houve declaração afirmativa quanto à prática avaliada: rotinas de monitoramento do desempenho da gestão de tecnologia da informação estão definidas (E1).

A ausência ou a insuficiência de um modelo básico de governança e gestão de TIC acarreta o risco de indefinição sobre a direção estratégica da tecnologia da informação e sobre os resultados esperados da função de TIC.

Instituição formal do Comitê de TIC ou instância equivalente

O Comitê de TIC ou instância equivalente é mecanismo relevante para estruturar a participação da alta administração e das áreas interessadas nas decisões de tecnologia da informação. Sua formalização permite definir composição, competências, periodicidade mínima, forma de deliberação e responsabilidades pelo acompanhamento das decisões.

O Decreto nº 12.198/2024, art. 5º, adotado como critério de referência, prevê colegiado responsável por definir diretrizes e estratégias sobre uso de recursos digitais no âmbito federal. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.1, reforça a necessidade de estrutura de governança de TI, especialmente Comitê de Tecnologia da Informação ou instância equivalente, com participação de áreas relevantes.

Em alinhamento, o COBIT 2019, no objetivo APO01.05, orienta a definição, comunicação e manutenção de papéis e responsabilidades relacionados à governança e gestão de TI.

A instituição formal do Comitê deve ser demonstrada por ato, norma, regimento, portaria ou documento equivalente que estabeleça a instância, sua composição, competências, periodicidade ou forma de deliberação.

Da análise das respostas ao item 1001 e da documentação apresentada, verificou-se que a instituição formal de Comitê de TIC ou instância equivalente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 1001, não houve declaração afirmativa quanto à prática avaliada: dispõe de comitê de tecnologia da informação composto por representantes de áreas relevantes da organização (E2).

A ausência de instituição formal do Comitê de TIC ou instância equivalente fragiliza a governança, uma vez que a organização deixa de contar com foro institucional normatizado para deliberação sobre prioridades, projetos, riscos, serviços, orçamento e contratações de TIC.

Conclusão

As fragilidades identificadas na governança de TIC reduzem a segurança de que a organização disponha de mecanismos suficientes para avaliar, dirigir e monitorar a tecnologia da informação de forma alinhada aos objetivos institucionais.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos mecanismos de governança de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração;
- **Comunicação com Recomendação** para que institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos.

Achado 3 – Planejamento de TIC insuficiente para orientar a gestão, o orçamento e as contratações de TIC

Critérios

- COBIT 2019, APO02.05 - Definir o plano e o roteiro estratégico: estabelecer plano e roteiro de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados;
- COBIT 2019, APO06.03 - Criar e manter orçamentos: elaborar e manter orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas;
- Acórdão 1.411/2014-TCU-Plenário, item 9.1.6 e subitens 9.1.6.1 a 9.1.6.4: necessidade de instituir formalmente plano diretor de TI, contemplando desdobramento de diretrizes estratégicas, vinculação das ações de TI a indicadores e metas de negócio, vinculação das ações de TI a indicadores e metas de serviços ao cidadão e vinculação das ações priorizadas ao orçamento de TI;
- Acórdão TCE-RJ 44.490/2024-PLEN, item II.3 e subitens II.3.1 a II.3.5: necessidade de estabelecer processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI, contemplando objetivos, indicadores e metas de TI alinhados aos objetivos de negócio, riscos que possam impactar objetivos e metas, projetos, aquisições e ações necessárias, alocação de recursos e ações de divulgação e monitoramento do PDTI após aprovação pela autoridade máxima.

Evidências

- **E1:** Resposta negativa ao detalhamento d) do item 2101 do Questionário, para verificar se o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
- **E2:** Resposta negativa ao detalhamento a) do item 2102 do Questionário, para verificar se o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração;
- **E3:** Resposta negativa ao detalhamento d) do item 2102 do Questionário, para verificar se as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA, planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias

superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal);

- **E4:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações;
- **E5:** Resposta negativa ao detalhamento c) do item 2802 do Questionário, para verificar se na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
- **E6:** Resposta negativa ao detalhamento d) do item 2802 do Questionário, para verificar se o PCA fundamenta a proposta orçamentária da organização;
- **E7:** Resposta negativa ao subitem b) do item 2804 do Questionário, para verificar se as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA);
- **E8:** Resposta negativa ao detalhamento e) do item 2102 do Questionário, para verificar se é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário.

Situação encontrada

O planejamento de TIC é instrumento fundamental para traduzir diretrizes institucionais em iniciativas, prioridades, recursos, prazos, responsáveis e resultados esperados. Sob a perspectiva de governança pública, a administração deve executar processo formal de planejamento, contar com plano de TIC formalmente aprovado, assegurar participação das áreas finalísticas, alinhar o plano ao planejamento institucional, integrá-lo ao orçamento e às contratações e acompanhá-lo periodicamente.

Os critérios de boas práticas indicam que o planejamento de TIC deve estabelecer plano e roteiro estratégico, manter orçamento alinhado ao portfólio e às prioridades aprovadas, vincular ações de TIC a indicadores, metas e orçamento de TI, e contemplar processo estruturado de elaboração, manutenção e revisão periódica do PDTI⁶.

Com base na análise das respostas aos itens 2101, 2102, 2802 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento integral a esses requisitos de planejamento. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

⁶ Os critérios de planejamento de TIC convergem para a necessidade de plano formal, aprovado, vigente, alinhado à estratégia institucional, integrado ao orçamento e às contratações e acompanhado periodicamente.

- **Processo formal de planejamento:** a fragilidade no processo de elaboração não demonstra aderência aos critérios do COBIT 2019 (APO02.05), do Acórdão 1.411/2014-TCU-Plenário e do Acórdão TCE-RJ 44.490/2024-PLEN, o que pode favorecer atuação reativa e sem critérios objetivos de seleção e priorização de iniciativas.
- **Aprovação formal do plano:** a ausência de aprovação formal não demonstra aderência aos critérios de formalização do planejamento de TIC, reduzindo sua legitimidade institucional para orientar a gestão, os projetos, o orçamento e as contratações da organização.
- **Alinhamento estratégico:** a falta de alinhamento ao planejamento institucional não demonstra aderência ao princípio de vinculação da TIC aos objetivos de negócio, o que pode resultar em investimentos e iniciativas com baixo valor público para o órgão.
- **Integração orçamentária e operacional:** a ausência de vínculo demonstrado com orçamento e contratações de TIC não demonstra aderência ao COBIT 2019 (APO06.03), ao Acórdão 1.411/2014-TCU-Plenário e ao Acórdão TCE-RJ 44.490/2024-PLEN, favorecendo aquisições reativas, não priorizadas e desalinhadas das metas de TIC.
- **Acompanhamento e revisão:** a ausência de acompanhamento ou atualização periódica não demonstra aderência aos critérios de manutenção e monitoramento do PDTI, elevando o risco de manutenção de metas, iniciativas e prioridades incompatíveis com mudanças institucionais, orçamentárias ou tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal de planejamento de TIC

O processo formal de planejamento de TIC deve definir etapas, responsáveis, participação das áreas demandantes e critérios mínimos de priorização. Esse processo é necessário para que o planejamento deixe de ser uma atividade eventual e passe a constituir rotina institucional de identificação, seleção, priorização e acompanhamento de demandas de tecnologia.

O COBIT 2019, no objetivo APO02.05, orienta a definição de plano e roteiro estratégico de TIC que traduzam a estratégia em iniciativas, prioridades, recursos, dependências, prazos e benefícios esperados. O Acórdão TCE-RJ 44.490/2024-PLEN, item II.3, também aponta a necessidade de processo estruturado, com participação de representantes das principais secretarias, para elaborar, manter e revisar periodicamente o PDTI.

O processo deve ser demonstrado por norma, procedimento, guia ou instrumento equivalente que discipline a elaboração, revisão, aprovação e acompanhamento do planejamento de TIC.

Da análise das respostas ao item 2101 e da documentação apresentada, verificou-se que o processo formal de planejamento de TIC não se mostrou suficientemente estruturado quanto a etapas, responsáveis, participação das áreas demandantes e critérios de priorização, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2101, não houve declaração afirmativa quanto à prática avaliada: o processo de planejamento de TI está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E1).

A inexistência ou fragilidade desse processo expõe a organização a uma atuação reativa e à alocação de recursos em iniciativas de tecnologia sem critérios claros de priorização.

Aprovação formal do plano de TIC

O plano de TIC deve ser formalmente aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado integrante da alta administração, de modo a conferir legitimidade institucional ao instrumento.

O Acórdão 1.411/2014-TCU-Plenário e o Acórdão TCE-RJ 44.490/2024-PLEN reforçam a necessidade de plano diretor ou instrumento equivalente formalmente instituído e aprovado, capaz de orientar as ações de TIC.

A aprovação deve ser demonstrada por ato formal da instância competente ou por registro equivalente que identifique o plano aprovado, a autoridade responsável e a data da deliberação.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que a aprovação formal do plano de TIC por autoridade ou instância competente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de tecnologia da informação (plano de TI) é aprovado pelo dirigente máximo da organização ou por dirigente ou colegiado que integra a alta administração (E2).

A ausência de comprovação da aprovação formal do plano de TIC reduz a segurança quanto à legitimidade institucional do instrumento para orientar a gestão, os projetos, o orçamento e as contratações de tecnologia da informação.

Alinhamento ao planejamento institucional

O plano de TIC deve demonstrar como suas iniciativas apoiam os objetivos institucionais, as diretrizes superiores e as necessidades das áreas finalísticas e administrativas.

O Acórdão 1.411/2014-TCU-Plenário exige o desdobramento de diretrizes estratégicas e a vinculação das ações de TI a indicadores e metas de negócio. O Acórdão TCE-RJ 44.490/2024-PLEN também prevê objetivos, indicadores e metas de TI alinhados aos objetivos de negócio.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que o alinhamento do plano de TIC ao planejamento institucional, às diretrizes superiores ou às necessidades das áreas finalísticas e administrativas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2102, não houve declaração afirmativa quanto à prática avaliada: as iniciativas de TI (projetos e ações) constantes do plano de TI alinham-se aos objetivos e iniciativas definidos no planejamento institucional (como PPA, planos estratégicos, planos setoriais e plano de governo, no caso de municípios), bem como, quando aplicável, às estratégias e diretrizes estabelecidas por instâncias superiores de governança (como a Estratégia Nacional de Tecnologia da Informação e Comunicação do Poder Judiciário - ENTIC-JUD, normas e orientações do SETIC/PRODERJ (para órgãos estaduais) ou instâncias de governança equivalentes no âmbito municipal) (E3).

A ausência desse alinhamento eleva o risco de execução de iniciativas tecnológicas pouco aderentes às prioridades institucionais, às necessidades das áreas finalísticas e administrativas e à geração de valor público.

Vínculo com orçamento e contratações de TIC

O planejamento de TIC deve ser vinculado com a proposta orçamentária, o plano de contratações e as contratações executadas. Essa integração é necessária para que as iniciativas priorizadas tenham suporte financeiro, sejam convertidas em contratações coerentes e possam ser acompanhadas ao longo da execução.

O COBIT 2019, APO06.03, orienta a criação e manutenção de orçamento de TIC alinhado ao portfólio, ao planejamento e às prioridades aprovadas. O Acórdão 1.411/2014-TCU-Plenário também exige vinculação das ações priorizadas ao orçamento de TI, e o Acórdão TCE-RJ 44.490/2024-PLEN prevê projetos, aquisições, ações necessárias e alocação de recursos no PDTI.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o vínculo entre o plano de TIC, a proposta orçamentária, o

plano de contratações ou as contratações de TIC executadas não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E4);
- No subitem c) do item 2802, não houve declaração afirmativa quanto à prática avaliada: na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E5);
- No subitem d) do item 2802, não houve declaração afirmativa quanto à prática avaliada: o PCA fundamenta a proposta orçamentária da organização (E6);
- No subitem b) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA) (E7).

A falta de integração demonstrada entre o planejamento de tecnologia, as previsões orçamentárias, o plano de contratações e as contratações executadas eleva o risco de aquisições isoladas, reativas ou insuficientemente priorizadas sob a perspectiva técnica.

Acompanhamento, revisão e atualização do plano de TIC

O plano de TIC deve ser acompanhado, revisto e atualizado periodicamente ou diante de mudanças relevantes, com registro de execução, pendências, reprogramações e deliberações. Essa rotina permite verificar o andamento das iniciativas, ajustar prioridades e manter o plano compatível com mudanças institucionais, orçamentárias ou tecnológicas.

O Acórdão TCE-RJ 44.490/2024-PLEN prevê a manutenção e revisão periódica do PDTI, bem como ações de divulgação e monitoramento após sua aprovação pela autoridade máxima.

Da análise das respostas ao item 2102 e da documentação apresentada, verificou-se que a rotina de acompanhamento, revisão ou atualização periódica do plano de TIC não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem e) do item 2102, não houve declaração afirmativa quanto à prática avaliada: é feito acompanhamento concomitante à execução do plano de TI, com vistas a assegurar sua observância e possibilitar a realização de ajustes que se fizerem necessário (E8).

A ausência de rotina sistemática de monitoramento e atualização dificulta a adaptação do planejamento de TIC a mudanças no contexto institucional, orçamentário ou tecnológico, elevando o risco de manutenção de iniciativas, prioridades ou metas desatualizadas.

Conclusão

As fragilidades identificadas no planejamento de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de processo e instrumento suficientes para direcionar iniciativas, priorizar recursos, alinhar projetos às necessidades institucionais e integrar orçamento e contratações à estratégia de tecnologia.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de planejamento de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC;
- **Comunicação com Recomendação** para que submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação;
- **Comunicação com Recomendação** para que revise o plano de TIC para explicitar seu alinhamento ao planejamento institucional, às diretrizes superiores e às necessidades das áreas finalísticas e administrativas, relacionando objetivos, iniciativas, indicadores e metas de TIC aos resultados institucionais pretendidos;
- **Comunicação com Recomendação** para que integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização;
- **Comunicação com Recomendação** para que estabeleça e execute rotina periódica de acompanhamento, revisão e atualização do plano de TIC, atentando-se, minimamente, em registrar a execução das iniciativas, as pendências, as reprogramações e as deliberações adotadas.

Achado 4 – Capacidade institucional insuficiente para sustentar a gestão de TIC e segurança da informação

Critérios

- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir, comunicar e manter papéis e responsabilidades relacionados à governança e gestão de TIC;
- COBIT 2019, APO07.01 - Adquirir e manter pessoal adequado e apropriado: assegurar quantidade e perfil de profissionais compatíveis com as necessidades de TIC;
- COBIT 2019, APO07.03 - Manter habilidades e competências do pessoal: identificar, desenvolver e manter competências necessárias à execução das responsabilidades de TIC;
- COBIT 2019, APO07.05 - Planejar e monitorar o uso de recursos humanos de TI e de negócio: planejar, alocar e acompanhar capacidade de pessoal para iniciativas, operações e serviços de TIC;
- COBIT 2019, APO07.06 - Gerenciar pessoal contratado: controlar o uso de pessoal terceirizado ou externo, preservando responsabilização, supervisão e retenção de conhecimento;
- COBIT 2019, APO10.04 - Gerenciar risco de fornecedores: identificar e tratar riscos decorrentes de fornecedores, contratos e dependências externas relevantes para TIC;
- COBIT 2019, DSS01.02 - Gerenciar serviços de TI terceirizados: assegurar que serviços terceirizados sejam supervisionados, medidos e integrados aos controles da organização;
- ABNT NBR ISO/IEC 27001:2022, cláusulas 5.3 e 7.2: definir responsabilidades e autoridades para segurança da informação e assegurar competências necessárias às funções atribuídas;
- ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3: definir papéis e responsabilidades de segurança da informação e promover conscientização, educação e treinamento em segurança.

Evidências

- **E1:** Resposta negativa ao detalhamento c) do item 2703 do Questionário, para verificar se definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação;

- **E2:** Resposta negativa ao detalhamento a) do item 2701 do Questionário, para verificar se as responsabilidades e atribuições dos gestores da área de tecnologia da informação estão definidas, documentadas e publicadas;
- **E3:** Resposta negativa ao detalhamento a) do item 2702 do Questionário, para verificar se as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas;
- **E4:** Resposta negativa ao detalhamento b) do item 2704 do Questionário, para verificar se os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado;
- **E5:** Resposta negativa ao detalhamento b) do item 2705 do Questionário, para verificar se as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas;
- **E6:** Resposta negativa ao detalhamento c) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E7:** Resposta negativa ao detalhamento d) do item 2705 do Questionário, para verificar se as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas;
- **E8:** Predomínio de profissionais terceirizados de TI em relação ao quantitativo de profissionais internos, conforme informado em resposta ao item 0105.

Situação encontrada

A capacidade institucional de TIC e segurança da informação pressupõe dispor de recursos humanos, competências, perfis profissionais, funções e vínculos contratuais adequados para planejar, coordenar, gerir, proteger, contratar, fiscalizar e sustentar o ambiente tecnológico. Sob a perspectiva de controle e governança, a estruturação formal de uma unidade de tecnologia deve ser acompanhada de capacidade técnica compatível para exercer a supervisão de suas atribuições estratégicas.

Os critérios de boas práticas indicam que a organização deve formalizar a designação de papéis e responsabilidades, assegurar o dimensionamento apropriado do

quadro de pessoal, mapear funções críticas, capacitar periodicamente a equipe e supervisionar de forma estrita a atuação de prestadores de serviços externos⁷.

Com base na análise das respostas aos itens 0101, 0105, 2701, 2702, 2703, 2704, 2705, 2706, 2708, 2801 e 2804 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada capacidade institucional suficiente para sustentar a gestão de TIC e segurança da informação. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Dimensionamento de pessoal:** a ausência de definição de parâmetros de pessoal não demonstra aderência aos critérios de planejamento de recursos humanos (COBIT 2019, APO07.01), elevando o risco de subdimensionamento ou má alocação da equipe técnica.
- **Perfis profissionais:** a ausência ou inobservância de perfis profissionais mínimos para a escolha de gestores e técnicos não demonstra aderência às diretrizes de manutenção de competências (COBIT 2019, APO07.01/APO07.03 e ISO/IEC 27002:2022, 5.2/6.3), reduzindo a segurança de que os responsáveis possuam qualificação compatível com as funções exercidas.
- **Lacunas de competência:** a ausência de identificação ou tratamento de lacunas de treinamento não demonstra aderência às recomendações de capacitação técnica (COBIT 2019, APO07.03 e ISO/IEC 27002:2022, 6.3), podendo fragilizar a operação de segurança e o gerenciamento de ativos de TIC.
- **Dependência externa:** a dependência externa relevante sem capacidade interna suficiente para coordenar e fiscalizar a TIC não demonstra aderência às boas práticas de gestão de pessoal contratado e terceirizações (COBIT 2019, APO07.06, APO10.04 e DSS01.02), elevando riscos à governabilidade técnica e à continuidade das atividades do órgão.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Quantitativo necessário de pessoal de TIC e segurança da informação

A definição do quantitativo necessário de pessoal permite avaliar se a força de trabalho disponível é compatível com as demandas, riscos e responsabilidades da organização.

O COBIT 2019, APO07.01 e APO07.05, exige que a organização assegure quantidade e perfil de profissionais compatíveis com as necessidades de TIC e planeje a alocação de recursos humanos para iniciativas, operações e serviços.

⁷ Os critérios de capacidade institucional de TIC e segurança da informação concentram-se em pessoal adequado, competências, papéis, responsabilidades, retenção de conhecimento e supervisão de terceiros.

Da análise das respostas ao item 2703 e da documentação apresentada, verificou-se que a definição do quantitativo necessário de pessoal de TIC e segurança da informação com base em critério ou procedimento técnico não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2703, não houve declaração afirmativa quanto à prática avaliada: definiu-se, de maneira documentada, um quantitativo necessário de pessoal da área de tecnologia da informação e segurança da informação (E1).

A ausência de dimensionamento técnico do quadro de pessoal reduz a disponibilidade de bases objetivas para subsidiar decisões sobre contratações, provimentos, planos de capacitação ou eventual compartilhamento de estruturas com outras organizações.

Perfis profissionais de TIC e segurança da informação

A definição de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação é necessária para que as pessoas designadas possuam competências compatíveis com suas responsabilidades.

O COBIT 2019, APO01.05 e APO07.03, orienta a definição de papéis, responsabilidades e competências necessárias. A ABNT NBR ISO/IEC 27001:2022 também exige competências adequadas às funções atribuídas em segurança da informação.

Da análise das respostas aos itens 2701, 2702 e 2704 e da documentação apresentada, verificou-se que a definição ou utilização de perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2701, não houve declaração afirmativa quanto à prática avaliada: as responsabilidades e atribuições dos gestores da área de tecnologia da informação estão definidas, documentadas e publicadas (E2);
- No subitem a) do item 2702, não houve declaração afirmativa quanto à prática avaliada: as responsabilidades e atribuições das ocupações ou grupo de ocupações da área de tecnologia da informação estão definidas, documentadas e publicadas (E3);
- No subitem b) do item 2704, não houve declaração afirmativa quanto à prática avaliada: os gestores são selecionados com base em perfil profissional previamente definido e documentado, e compatível com o cargo ou função para o qual tenha sido indicado (E4).

A ausência de perfis profissionais mínimos ou de sua utilização como referência para designação de gestores e técnicos eleva o risco de alocação de colaboradores sem

qualificação compatível com atividades críticas de tecnologia da informação e segurança da informação.

Identificação e tratamento de lacunas de competências

A organização deve identificar periodicamente lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e definir medidas de tratamento, como capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento.

O COBIT 2019, APO07.03, orienta a manutenção de habilidades e competências necessárias à execução das responsabilidades de TIC. A ABNT NBR ISO/IEC 27002:2022, controles 5.2 e 6.3, reforça a definição de responsabilidades e a promoção de conscientização, educação e treinamento em segurança.

Da análise das respostas aos itens 2705 e 2706 e da documentação apresentada, verificou-se que a identificação ou o tratamento de lacunas de competências dos gestores e colaboradores de TIC e segurança da informação não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem b) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências de liderança e gestão necessárias para a atuação dos gestores da organização são identificadas e documentadas (E5);
- No subitem c) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de tecnologia da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E6);
- No subitem d) do item 2705, não houve declaração afirmativa quanto à prática avaliada: as lacunas de competências técnicas da área de segurança da informação necessárias para a atuação dos colaboradores da organização são identificadas e documentadas (E7).

A ausência de diagnóstico regular sobre competências internas e de medidas para tratamento de lacunas dificulta o acompanhamento da evolução tecnológica e pode reduzir a capacidade da equipe técnica de administrar sistemas, infraestrutura e controles de segurança da informação de forma compatível com os riscos existentes.

Dependência externa e capacidade interna de coordenação e fiscalização

A utilização de terceiros ou de estrutura externa para execução de atividades de TIC não elimina a responsabilidade da organização pela coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento.

O COBIT 2019, APO07.06, APO10.04 e DSS01.02, orienta o controle de pessoal contratado, a gestão de riscos de fornecedores e a supervisão de serviços terceirizados de TI, preservando responsabilização, medição, integração aos controles e retenção de conhecimento.

Da análise das respostas aos itens 0101 e 0105 e da documentação apresentada, verificou-se que a existência de capacidade interna para coordenar, planejar, fiscalizar e reter conhecimento quando a operação de TIC depende de terceiros ou de estrutura externa não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- O quantitativo informado indicou predominância de profissionais terceirizados em relação aos profissionais internos de TIC (E8).

O estabelecimento de modelo operacional baseado predominantemente em recursos externos, sem capacidade interna suficiente de coordenação e supervisão, pode reduzir a governabilidade técnica, a retenção de conhecimento e a continuidade das operações de TIC.

Conclusão

As fragilidades identificadas na capacidade institucional de TIC e segurança da informação reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de pessoal, competências, papéis, perfis profissionais e mecanismos de supervisão suficientes para sustentar a gestão, a proteção, as contratações, a fiscalização e a continuidade dos serviços tecnológicos.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à adequação dos aspectos de capacidade institucional de TIC e segurança da informação efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes;
- **Comunicação com Recomendação** para que defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis;

- **Comunicação com Recomendação** para que realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento;
- **Comunicação com Recomendação** para que avalie o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa.

Achado 5 – Gestão de serviços de TIC insuficiente para assegurar controle sobre serviços, ativos e incidentes

CrITÉRIOS

- ITIL 4, prática de gerenciamento do catálogo de serviços: manter fonte única de informações consistentes sobre serviços e ofertas de serviço, disponível para usuários e equipes de suporte;
- COBIT 2019, APO09.02 - Catalogar serviços facilitados por TI: definir, manter e comunicar catálogo de serviços, incluindo serviços prestados, características, requisitos e níveis de serviço esperados;
- ITIL 4, prática de gerenciamento de nível de serviço: definir, acordar, monitorar, avaliar e reportar metas e níveis de serviço alinhados às necessidades das áreas usuÁrias;
- ITIL 4, prática de gerenciamento de ativos de TI: planejar e gerenciar o ciclo de vida dos ativos de TI, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão;
- ITIL 4, prática de gerenciamento de configuração de serviço: assegurar informações precisas e confiÁveis sobre itens de configuração e seus relacionamentos com serviços, sistemas e infraestrutura;
- COBIT 2019, BAI10.01 - Estabelecer e manter um modelo de configuração: definir escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração;
- ITIL 4, prática de gerenciamento de incidentes: minimizar o impacto negativo dos incidentes por meio da restauração tempestiva da operação normal dos serviços e do registro rastreÁvel do tratamento realizado;
- COBIT 2019, DSS02.02, DSS02.04 e DSS02.07 - Requisições de serviço e incidentes gerenciados: registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Evidências

- **E1:** Resposta negativa ao detalhamento a) do item 2201 do Questionário, para verificar se o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes);

- **E2:** Resposta negativa ao detalhamento b) do item 2201 do Questionário, para verificar se o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização;
- **E3:** Resposta negativa ao detalhamento d) do item 2201 do Questionário, para verificar se são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes;
- **E4:** Resposta negativa ao detalhamento e) do item 2201 do Questionário, para verificar se a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS;
- **E5:** A organização declarou “Sim” no subitem a) do item 2203, mas a evidência encaminhada foi considerada insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles;
 - Justificativa da avaliação: O item é considerado não conforme, visto que a tela de monitoramento apresentada não caracteriza uma base de dados de configuração (CMDB) consolidada. A evidência demonstra apenas uma listagem técnica de roteadores com endereços IP e status, sem detalhar as configurações dos serviços de TI e os relacionamentos entre os ativos e as entregas de valor. Constata-se a ausência de uma base de dados que integre ativos e serviços de negócio, inviabilizando a comprovação do requisito de relacionamento;
- **E6:** Resposta negativa ao detalhamento c) do item 2203 do Questionário, para verificar se o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
- **E7:** Resposta negativa ao detalhamento a) do item 2204 do Questionário, para verificar se a organização definiu regras para a priorização e o escalamento de incidentes;
- **E8:** A organização declarou “Sim” no subitem d) do item 2204, mas a evidência encaminhada foi considerada insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades);
 - Justificativa da avaliação: A avaliação realizada indica que não há evidências da formalização do processo de gestão de incidentes. O pacote de evidências

restringe-se a capturas de tela de uma ferramenta de tecnologia, sem a apresentação de norma, política, guia ou procedimento institucional que defina as diretrizes do processo e as responsabilidades dos envolvidos. A falta de um documento formal de normatização constitui a lacuna que impede a conformidade. É necessário apresentar o documento ou ato institucional que estabeleça o processo;

- **E9:** Resposta negativa ao detalhamento e) do item 2204 do Questionário, para verificar se a organização definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa.

Situação encontrada

A gestão de serviços de TIC organiza a forma como as soluções e o suporte tecnológico são entregues aos usuários e às áreas demandantes do órgão. Catálogo de serviços, Acordos de Nível de Serviço (ANS), inventário de ativos, gestão de configuração e gestão de incidentes constituem práticas básicas e integradas necessárias para assegurar a transparência operacional, continuidade do negócio, governabilidade financeira, controle de ativos e qualidade de suporte técnico.

Os critérios de boas práticas baseados na ITIL 4 e no COBIT 2019 indicam que a organização deve manter fonte unificada e consistente de informações sobre seu catálogo, estabelecer metas mensuráveis de atendimento, administrar ativamente o ciclo de vida dos ativos tecnológicos, rastrear os relacionamentos lógicos de configuração e registrar de forma sistemática e auditável todas as ocorrências operacionais e incidentes de segurança⁸.

Com base na análise das respostas aos itens 2201, 2203, 2204 e 2504 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrada adoção suficiente dessas práticas mínimas. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

- **Catálogo de serviços de TIC:** a fragilidade ou ausência do catálogo não demonstra aderência à ITIL 4 e ao COBIT 2019 (APO09.02), podendo resultar em prestação reativa, sem transparência ou definição clara das entregas técnicas disponíveis.
- **Níveis mínimos de serviço:** a ausência de parâmetros ou acompanhamento não demonstra aderência aos critérios de catálogo e gerenciamento de nível de serviço (ITIL 4 e COBIT 2019, APO09.02), dificultando a avaliação objetiva da qualidade e tempestividade dos serviços prestados.

⁸ As práticas de gestão de serviços de TIC adotadas como critério baseiam-se em ITIL 4 e COBIT 2019 e abrangem catálogo, níveis de serviço, ativos, configuração e incidentes.

- **Inventário de ativos de TIC:** a fragilidade ou inexistência de inventário não demonstra aderência à prática de gerenciamento de ativos de TI (ITIL 4), reduzindo o controle sobre recursos tecnológicos, licenciamentos de software, custos e riscos associados.
- **Gestão de configuração:** a ausência de mapeamento lógico não demonstra aderência à ITIL 4 e ao COBIT 2019 (BAI10.01), podendo prejudicar a confiabilidade das dependências operacionais entre infraestrutura, sistemas e serviços críticos.
- **Gestão de incidentes de TIC:** a inexecução ou informalidade no processo de atendimento não demonstra aderência à ITIL 4 e ao COBIT 2019 (DSS02.02, DSS02.04 e DSS02.07), dificultando o tratamento padronizado, tempestivo e rastreável de falhas tecnológicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Catálogo de serviços de TIC

O catálogo de serviços de TIC deve constituir fonte única de informações consistentes sobre os serviços prestados, acessível aos usuários e às áreas demandantes. Deve conter informações mínimas sobre os serviços efetivamente prestados, suas características, requisitos, canais de atendimento e níveis esperados de serviço.

A ITIL 4, na prática de gerenciamento do catálogo de serviços, orienta a manutenção de informações consistentes e disponíveis sobre serviços e ofertas de serviço. O COBIT 2019, APO09.02, exige a definição, manutenção e comunicação do catálogo de serviços facilitados por TI.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a existência de catálogo de serviços de TIC atualizado, acessível aos usuários e com informações mínimas sobre os serviços prestados não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo contém as metas definidas para cada serviço (p. ex.: prazos de entrega, horários de serviço e de suporte, bem como pontos de contato para solicitação do serviço, envio de sugestões, esclarecimento de dúvidas e reporte de incidentes) (E1);
- No subitem b) do item 2201, não houve declaração afirmativa quanto à prática avaliada: o catálogo está atualizado e as informações que nele constam são compatíveis com os Acordos de Níveis de Serviço (ANS) estabelecidos pela área de tecnologia da informação e as áreas de negócio da organização (E2).

A inexistência, desatualização ou falta de divulgação do catálogo de serviços dificulta que os usuários conheçam o portfólio de entregas e os canais corretos de atendimento, elevando o risco de prestação de suporte de forma reativa, informal ou pouco transparente.

Níveis de serviço e metas de atendimento

A definição de Acordos de Níveis de Serviço, metas mínimas ou parâmetros equivalentes permite pactuar expectativas, medir desempenho e avaliar a qualidade dos principais serviços de TIC.

A ITIL 4, na prática de gerenciamento de nível de serviço, orienta a definição, monitoramento, avaliação e reporte de metas e níveis de serviço alinhados às necessidades das áreas usuárias. O COBIT 2019, APO09.02, também relaciona o catálogo à comunicação de requisitos e níveis de serviço esperados.

Da análise das respostas ao item 2201 e da documentação apresentada, verificou-se que a definição ou o monitoramento de níveis mínimos de serviço, metas ou parâmetros equivalentes para os serviços de TIC relevantes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem d) do item 2201, não houve declaração afirmativa quanto à prática avaliada: são formalizados ANS contendo metas de nível de serviço acordadas com representantes das áreas de negócio clientes (E3);
- No subitem e) do item 2201, não houve declaração afirmativa quanto à prática avaliada: a área de gestão de tecnologia da informação monitora continuamente o alcance dos níveis de serviço estabelecidos nos ANS (E4).

A ausência de níveis mínimos de serviço, metas estruturadas ou parâmetros equivalentes reduz a disponibilidade de bases objetivas para monitorar e avaliar a qualidade, o tempo de resposta e a eficiência dos serviços prestados.

Inventário de ativos de TIC

O inventário de ativos de TIC deve permitir conhecer e controlar equipamentos, servidores, sistemas, *softwares*, licenças, serviços em nuvem, responsáveis e componentes de infraestrutura.

A ITIL 4, na prática de gerenciamento de ativos de TI, orienta o gerenciamento do ciclo de vida dos ativos, mantendo informações suficientes para apoiar controle, custo, risco, valor e tomada de decisão.

Da análise das respostas aos itens 2203 e 2504 e da documentação apresentada, verificou-se que a existência de inventário de ativos de TIC atualizado e abrangente não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E5).

A ausência de inventário atualizado e abrangente de ativos de TIC reduz a segurança quanto ao controle sobre equipamentos, sistemas, softwares, licenças, serviços em nuvem e componentes de infraestrutura, elevando riscos relacionados a custos, conformidade, segurança da informação e planejamento de capacidade.

Gestão de configuração

A gestão de configuração deve manter informações precisas e confiáveis sobre itens de configuração relevantes, seus atributos, responsáveis e relacionamentos com ativos, sistemas, infraestrutura e serviços.

A ITIL 4, na prática de gerenciamento de configuração de serviço, orienta assegurar informações confiáveis sobre itens de configuração e seus relacionamentos. O COBIT 2019, BAI10.01, exige a definição de escopo, granularidade, atributos, relacionamentos e responsáveis pela base de configuração.

Da análise das respostas ao item 2203 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de configuração com registro de itens relevantes, atributos, responsáveis e relacionamentos entre ativos, sistemas, infraestrutura e serviços não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2203, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que mantém uma base de dados consolidada e atualizada com as configurações dos serviços e ativos de TI e o relacionamento entre eles (E5);
- No subitem c) do item 2203, não houve declaração afirmativa quanto à prática avaliada: o processo de gestão de configuração e ativos está formalizado (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E6).

A ausência de registros suficientes de configuração dificulta o mapeamento lógico das dependências entre servidores, bancos de dados, aplicações e serviços finalísticos, podendo reduzir a capacidade de análise de riscos em mudanças operacionais e de tratamento de falhas sistêmicas.

Gestão de incidentes de TIC

A gestão de incidentes de TIC deve definir papéis, responsabilidades, critérios de priorização, escalamento, tratamento, registro sistemático, histórico das ocorrências e análise posterior de incidentes relevantes ou recorrentes.

A ITIL 4, na prática de gerenciamento de incidentes, orienta minimizar impactos negativos por meio da restauração tempestiva da operação normal e do registro rastreável do tratamento realizado. O COBIT 2019, DSS02.02, DSS02.04 e DSS02.07, exige registrar, classificar, priorizar, investigar, diagnosticar, resolver, acompanhar e reportar incidentes e requisições de serviço.

Da análise das respostas ao item 2204 e da documentação apresentada, verificou-se que a existência de processo mínimo de gestão de incidentes de TIC com papéis, critérios de priorização, escalamento, tratamento, registro sistemático e análise posterior de ocorrências relevantes ou recorrentes não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2204, não houve declaração afirmativa quanto à prática avaliada: definiu regras para a priorização e o escalamento de incidentes (E7);
- No subitem d) do item 2204, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o(s) processo(s) de gestão de incidentes está(ão) formalizado(s) (a organização instituiu norma interna, guia ou instrumento similar com orientações quanto à execução do processo e definição de responsabilidades) (E8);
- No subitem e) do item 2204, não houve declaração afirmativa quanto à prática avaliada: definiu procedimentos e responsabilidades quanto à notificação e ao tratamento das notificações de incidentes de segurança da informação, bem como quanto à adoção de ações emergenciais, diretrizes para escalamento e comunicação interna e externa (E9).

O tratamento assistemático ou sem registro centralizado das falhas tecnológicas dificulta o acompanhamento do histórico de incidentes, a identificação de causas raiz e a redução do período de indisponibilidade dos sistemas corporativos.

Conclusão

As fragilidades identificadas na gestão de serviços de TIC reduzem a segurança de que a organização disponha, conforme aplicável ao caso concreto, de práticas suficientes para assegurar eficiência, continuidade, rastreabilidade, qualidade dos serviços prestados e controle sobre ativos, configurações e incidentes.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação das práticas de gestão de serviços de TIC

efetivamente apontadas neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes;
- **Comunicação com Recomendação** para que defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados;
- **Comunicação com Recomendação** para que estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças;
- **Comunicação com Recomendação** para que formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes.

Achado 6 – Fragilidades na governança técnica da fase preparatória das contratações de TIC

Critérios

- Art. 11, parágrafo único, da Lei 14.133/2021: responsabilidade da alta administração pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos;
- Art. 18, caput e §1º, incisos I, IV, V, VIII, IX, X e XIII, da Lei 14.133/2021: fase preparatória caracterizada pelo planejamento, compatibilização com o plano de contratações anual e elementos mínimos do estudo técnico preliminar;
- Art. 19, inciso IV, da Lei 14.133/2021: instituição de modelos de minutas de editais, termos de referência, contratos padronizados e demais documentos;
- Art. 7º, caput, incisos I a III e §1º, da Lei 14.133/2021: designação de agentes públicos para funções essenciais, observados atribuições, formação, segregação de funções e inexistência de vínculos que comprometam a atuação;
- COBIT 2019, APO01.05 - Estabelecer papéis e responsabilidades: definir e comunicar papéis e responsabilidades relacionados à informação e à tecnologia;
- COBIT 2019, APO01.09 - Definir e comunicar políticas e procedimentos: manter políticas, procedimentos e orientações para direcionar processos de gestão de TIC;

Evidências

- **E1:** A organização declarou “Sim” no subitem a) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: Não há definição de um processo de trabalho voltado ao planejamento de contratações de TI, com delimitação de etapas e responsabilidades específicas. A documentação limita-se a modelos de contratação genéricos, carecendo de elementos que contemplem as especificidades do planejamento de soluções tecnológicas. Existe a lacuna de comprovação de um processo de planejamento estruturado para TI;
- **E2:** A organização declarou “Sim” no subitem c) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a seleção de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;

- Justificativa da avaliação: O processo de seleção de fornecedores apresentado refere-se a práticas gerais de licitação, não contemplando etapas ou procedimentos específicos para a seleção em TI. Não foram evidenciados fluxos que considerem as particularidades técnicas e de mercado deste setor. A evidência é considerada insuficiente por ausência de um processo focado em TI;
- **E3:** A organização declarou “Sim” no subitem d) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes;
 - Justificativa da avaliação: Embora existam modelos de editais e listas de verificação de habilitação genéricos, não foram apresentados artefatos de seleção contendo critérios de julgamento ou requisitos técnicos específicos para TI. A evidência é insuficiente por tratar apenas de contratações de caráter geral, sem artefatos voltados para contratações de tecnologia;
- **E4:** A organização declarou “Sim” no subitem e) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa;
 - Justificativa da avaliação: Não foram identificados fluxos de trabalho ou manuais de gestão e fiscalização de contratos voltados especificamente à área de tecnologia da informação. A ausência de definição de responsabilidades e artefatos de controle para esta área caracteriza a insuficiência da evidência apresentada;
- **E5:** A organização declarou “Sim” no subitem g) do item 2801, mas a evidência encaminhada foi considerada insuficiente para comprovar que os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas;
 - Justificativa da avaliação: A ausência de processos de trabalho e artefatos específicos para TI impede a verificação da aderência a normas legais e infralegais que regem as contratações de tecnologia. A conformidade não pôde ser atestada devido à falta de documentos direcionados às especificidades do setor de TI, configurando a evidência como insuficiente;

- **E6:** Resposta negativa ao detalhamento c) do item 2102 do Questionário, para verificar se o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações;
- **E7:** Resposta negativa ao detalhamento c) do item 2802 do Questionário, para verificar se na elaboração do PCA são considerados os demais instrumentos de planejamento da organização;
- **E8:** Resposta negativa ao detalhamento d) do item 2802 do Questionário, para verificar se o PCA fundamenta a proposta orçamentária da organização;
- **E9:** Resposta negativa ao subitem b) do item 2804 do Questionário, para verificar se as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA);
- **E10:** Resposta negativa ao subitem c) do item 2804 do Questionário, para verificar se a fase de planejamento de cada contratação de TI é conduzida por uma Equipe de Planejamento da Contratação formalmente designada (composta, minimamente, por integrante requisitante e integrante técnico da área de TI).

Situação encontrada

As contratações de TIC devem observar governança técnica, planejamento prévio proporcional à complexidade do objeto, participação da área de tecnologia quando cabível e critérios objetivos para recebimento e mensuração de resultados. A complexidade dos ativos de tecnologia, as exigências de conformidade legal, incluindo LGPD quando aplicável, e a dependência das atividades finalísticas em relação aos serviços de TIC demandam controles compatíveis com a relevância, o risco e o valor da contratação.

Os critérios previstos na Lei 14.133/2021, na Lei 13.709/2018 (LGPD) e nos objetivos do COBIT 2019 disciplinam que a alta administração responde pela governança das contratações, que a fase preparatória deve ser instruída com planejamento compatível com o objeto e que os Termos de Referência (TR), projetos básicos, contratos ou instrumentos equivalentes devem conter requisitos, modelos de execução, critérios de medição e parâmetros de acompanhamento proporcionais à natureza da contratação⁹.

Com base na análise das respostas aos itens 2801, 2804, 2102 e 2802 do questionário aplicado e da avaliação das evidências documentais anexadas, não foi demonstrado atendimento suficiente das contratações de TIC da organização a essas diretrizes. A Equipe de Auditoria identificou fragilidades nos seguintes aspectos:

⁹ Os critérios de contratações de TIC combinam requisitos legais da Lei 14.133/2021, requisitos de segurança e proteção de dados da LGPD e boas práticas do COBIT 2019 sobre requisitos, papéis, procedimentos, contratos e desempenho de fornecedores.

- **Processo de contratação de TIC:** a fragilidade ou ausência de fluxo padronizado contraria a governança de contratações (Lei 14.133/2021, art. 11/art. 19, IV) e o COBIT 2019 (APO01.09), acarretando indefinição de papéis, ritos processuais e prazos internos.
- **Alinhamento ao planejamento:** a ausência de alinhamento demonstrado ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não demonstra aderência à Lei 14.133/2021 (arts. 11 e 18), podendo resultar em aquisições reativas ou sem lastro orçamentário adequado.
- **Equipe de planejamento:** a ausência de portaria ou designação de equipe mista com representação técnica de TIC, quando aplicável, não demonstra aderência à governança pública e à Lei 14.133/2021 (art. 7º), podendo comprometer a qualidade e a imparcialidade das especificações técnicas.

Essas situações ensejaram o presente achado e serão detalhadas nas subseções seguintes.

Processo formal e padronizado para contratações de TIC

O processo de contratação de TIC deve estabelecer fluxo, etapas, papéis, responsabilidades, modelos mínimos de artefatos, manuais, checklists ou orientações internas. Esses elementos reduzem improvisação, aumentam padronização e permitem controle sobre a qualidade da instrução processual.

O art. 11, parágrafo único, da Lei 14.133/2021 atribui à alta administração responsabilidade pela governança das contratações, com processos, estruturas, gestão de riscos e controles internos. O art. 19, inciso IV, prevê a instituição de modelos de documentos padronizados, e o COBIT 2019, APO01.09, orienta a definição e comunicação de políticas e procedimentos.

Da análise das respostas ao item 2801 e da documentação apresentada, verificou-se que a existência de processo formal e padronizado para contratações de TIC, com fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos proporcionais ao porte e aos riscos das contratações, não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem a) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para o planejamento das contratações de TI contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E1);
- No subitem c) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a seleção

de fornecedores contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E2);

- No subitem d) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que são disponibilizados artefatos padronizados para a fase de seleção de fornecedores, como minutas, checklists, modelos de edital, pareceres, critérios de julgamento ou documentos equivalentes (E3);
- No subitem e) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que o processo de trabalho para a gestão e fiscalização de contratos contempla as etapas, as responsabilidades dos atores envolvidos e os artefatos resultantes de cada etapa (E4);
- No subitem g) do item 2801, a organização declarou a prática avaliada, mas a evidência foi insuficiente para comprovar que os processos de trabalho e os artefatos padronizados estão aderentes às normas legais e infralegais que regem as contratações públicas (E5).

A ausência de fluxo processual regulamentado e de modelos padronizados reduz a segurança quanto à conformidade das contratações de TIC e eleva o risco de atrasos processuais, indefinição de papéis e inconsistências na elaboração dos documentos da fase preparatória.

Alinhamento ao planejamento, plano de contratações e proposta orçamentária

As contratações de TIC devem estar vinculadas ao planejamento de TIC, ao plano de contratações e à proposta orçamentária. Essa vinculação demonstra que a contratação decorre de prioridade definida, possui respaldo orçamentário e contribui para objetivos institucionais.

O art. 18 da Lei 14.133/2021 prevê a compatibilização da contratação com o plano de contratações anual e o planejamento da Administração. O art. 11 também reforça a responsabilidade da alta administração pela governança das contratações.

Da análise das respostas aos itens 2102, 2802 e 2804 e da documentação apresentada, verificou-se que o alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária não se mostrou suficientemente demonstrado, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2102, não houve declaração afirmativa quanto à prática avaliada: o plano de TI fundamenta a proposta orçamentária da área de TI e o plano de contratações (E6);

- No subitem c) do item 2802, não houve declaração afirmativa quanto à prática avaliada: na elaboração do PCA são considerados os demais instrumentos de planejamento da organização (E7);
- No subitem d) do item 2802, não houve declaração afirmativa quanto à prática avaliada: o PCA fundamenta a proposta orçamentária da organização (E8);
- No subitem b) do item 2804, não houve declaração afirmativa quanto à prática avaliada: as contratações de TI executadas no exercício encontram-se previamente estabelecidas nos instrumentos de planejamento vigentes (PDTI/PEDTIC e PCA) (E9).

A ausência de alinhamento das contratações de TIC ao planejamento de TIC, ao plano de contratações ou à proposta orçamentária eleva o risco de fragmentação de despesas, contratações reativas ou insuficientemente priorizadas e uso pouco eficiente dos recursos orçamentários.

Equipe de planejamento da contratação de TIC

As contratações de TIC devem contar com equipe de planejamento formalmente designada, com participação da área requisitante, da área técnica de TIC e das demais áreas necessárias. A designação formal favorece responsabilização, segregação de funções e qualidade técnica da instrução.

O art. 7º da Lei 14.133/2021 trata da designação de agentes públicos para funções essenciais, observadas atribuições, formação e segregação de funções. O COBIT 2019, APO01.05, orienta a definição e comunicação de papéis e responsabilidades.

Da análise das respostas ao item 2804 e da documentação apresentada, verificou-se que a designação formal de equipe de planejamento da contratação de TIC com participação da área requisitante, da área técnica de TIC e das demais áreas necessárias não se mostrou suficientemente demonstrada, em razão dos seguintes elementos identificados pela Equipe de Auditoria:

- No subitem c) do item 2804, não houve declaração afirmativa quanto à prática avaliada: a fase de planejamento de cada contratação de TI é conduzida por uma Equipe de Planejamento da Contratação formalmente designada (composta, minimamente, por integrante requisitante e integrante técnico da área de TI) (E10).

A ausência de designação formal da equipe de planejamento, com participação técnica de TIC quando aplicável, reduz a segurança quanto à qualidade técnica das estimativas de mercado, dos estudos de viabilidade e da especificação do objeto no ETP, no TR ou em instrumentos equivalentes.

Conclusão

As fragilidades evidenciadas na fase preparatória das contratações de TIC reduzem a segurança de que a organização disponha de controles suficientes para assegurar, conforme aplicável ao caso concreto, processo formal de contratação, participação técnica da área de TIC, alinhamento ao planejamento e adequada instrução dos processos. Essas fragilidades elevam o risco de contratações insuficientemente fundamentadas, pouco rastreáveis ou desalinhadas às necessidades institucionais, à complexidade e aos riscos das soluções de TIC pretendidas.

Em razão das lacunas descritas, são propostas recomendações preliminares voltadas à estruturação e à adequação dos aspectos da fase preparatória das contratações de TIC efetivamente apontados neste achado, observados os critérios aplicáveis indicados nas seções anteriores.

Propostas de Encaminhamento

- **Comunicação com Recomendação** para que formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis;
- **Comunicação com Recomendação** para que integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais;
- **Comunicação com Recomendação** para que designe formalmente equipe responsável pelo planejamento das contratações de TIC, atentando-se, minimamente, em assegurar a participação da área requisitante, da área técnica de TIC e das demais áreas necessárias, com definição das responsabilidades de seus integrantes.

4. Plano de ação

Para facilitar o atendimento das propostas constantes da Seção 3, a Equipe de Auditoria elaborou modelo preliminar de plano de ação contendo os encaminhamentos propostos à organização. O quadro não antecipa decisão final desta Corte de Contas e poderá ser revisto após a análise dos comentários do gestor.

Cumpra registrar que, em conformidade com o art. 4º, incisos I e II, da Deliberação TCE-RJ nº 346/2024, cabe à unidade jurisdicionada avaliar a conveniência e a oportunidade de implementar as recomendações. Ressalta-se, contudo, que a eventual decisão pela não aderência deve ser motivada: o gestor deve apresentar justificativa formal que demonstre, à luz das circunstâncias do caso concreto, as razões da decisão e, quando cabível, as medidas alternativas adotadas para tratar a situação que ensejou a recomendação.

Tabela 8 - Plano de ação contendo os encaminhamentos preliminarmente propostos

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
1	avale e ajuste o posicionamento organizacional da área de TIC, atentando-se, minimamente, em assegurar interlocução adequada com a alta administração e participação nas decisões estratégicas, orçamentárias, contratuais e de gestão de riscos relacionadas à tecnologia da informação			
2	estabeleça modelo básico de governança e gestão de TIC, atentando-se, minimamente, em definir papéis e responsabilidades, objetivos, indicadores, metas e forma de acompanhamento periódico do desempenho da TIC pela alta administração			
2	institua formalmente Comitê de TIC ou instância equivalente, compatível com o porte e a estrutura decisória da organização, atentando-se, minimamente, em definir sua composição, competências, periodicidade de reuniões, forma de registro das deliberações e acompanhamento dos encaminhamentos			
3	institua processo formal de planejamento de TIC, compatível com o porte e a maturidade da organização, atentando-se, minimamente, em definir etapas, responsáveis, participação das áreas demandantes e critérios de priorização das necessidades e iniciativas de TIC			
3	submeta o plano de TIC à aprovação formal do dirigente máximo ou de dirigente ou colegiado integrante da alta administração, mantendo registro do respectivo ato de aprovação			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
3	revise o plano de TIC para explicitar seu alinhamento ao planejamento institucional, às diretrizes superiores e às necessidades das áreas finalísticas e administrativas, relacionando objetivos, iniciativas, indicadores e metas de TIC aos resultados institucionais pretendidos			
3	integre o plano de TIC à proposta orçamentária, ao plano de contratações e às contratações de TIC, atentando-se, minimamente, em priorizar as demandas conforme sua relevância, seus riscos e a capacidade de execução da organização			
3	estabeleça e execute rotina periódica de acompanhamento, revisão e atualização do plano de TIC, atentando-se, minimamente, em registrar a execução das iniciativas, as pendências, as reprogramações e as deliberações adotadas			
4	estime e mantenha atualizado o quantitativo necessário de pessoal de TIC e segurança da informação, considerando o porte e a complexidade da organização, os serviços críticos, os sistemas mantidos, as contratações vigentes e os riscos relevantes			
4	defina perfis profissionais mínimos para gestores e colaboradores de TIC e segurança da informação, atentando-se, minimamente, em estabelecer conhecimentos, habilidades, experiência e responsabilidades requeridos e utilizar esses perfis na seleção e designação dos responsáveis			
4	realize diagnóstico periódico das lacunas de competências dos gestores e colaboradores de TIC e segurança da informação e estabeleça plano de tratamento, contemplando, conforme a necessidade, capacitação, realocação, provimento, apoio especializado, compartilhamento de estrutura ou contratação com transferência de conhecimento			
4	avale o modelo de operação de TIC e adote medidas proporcionais para assegurar capacidade interna suficiente de coordenação, planejamento, aprovação técnica, fiscalização contratual e retenção de conhecimento, especialmente quando a execução das atividades de TIC depender predominantemente de terceiros ou de estrutura externa			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
5	institua e mantenha atualizado catálogo de serviços de TIC, atentando-se, minimamente, em identificar os serviços efetivamente prestados, seus responsáveis, usuários, condições de acesso e informações necessárias ao atendimento das áreas demandantes			
5	defina, pactue e monitore níveis mínimos de serviço ou metas de atendimento para os serviços de TIC mais relevantes, estabelecendo indicadores, responsáveis, periodicidade de medição e forma de comunicação dos resultados			
5	estabeleça e mantenha atualizado inventário de ativos de TIC, atentando-se, minimamente, em registrar equipamentos, servidores, sistemas, softwares, licenças, serviços em nuvem, componentes de infraestrutura, responsáveis e informações necessárias ao controle do ciclo de vida dos ativos			
5	formalize e execute processo de gestão de configuração, atentando-se, minimamente, em manter base, ferramenta ou registro equivalente com os itens de configuração relevantes, seus responsáveis e os relacionamentos entre ativos, sistemas, infraestrutura e serviços, com atualização periódica e uso das informações no planejamento e acompanhamento de mudanças			
5	formalize e execute processo de gestão de incidentes de TIC, atentando-se, minimamente, em definir papéis, responsabilidades, critérios de priorização e escalamento, tratamento de incidentes de serviços e de segurança da informação, registro sistemático e rastreável das ocorrências e análise posterior dos incidentes relevantes ou recorrentes			
6	formalize e padronize o processo de contratação de TIC, compatível com o porte, a complexidade e os riscos das contratações da organização, atentando-se, minimamente, em definir fluxo, etapas, papéis, responsabilidades, instâncias de aprovação e modelos de artefatos, manuais, listas de verificação ou orientações internas aplicáveis			
6	integre as contratações de TIC ao planejamento de TIC, ao plano de contratações e à proposta orçamentária, atentando-se, minimamente, em registrar a necessidade atendida, a prioridade, a disponibilidade de recursos e a justificativa das situações excepcionais			

Achado	Medida proposta	Avaliação de		
		Viabilidade	Quem?	Quando?
6	designe formalmente equipe responsável pelo planejamento das contratações de TIC, atentando-se, minimamente, em assegurar a participação da área requisitante, da área técnica de TIC e das demais áreas necessárias, com definição das responsabilidades de seus integrantes			

(Fonte: elaboração própria)

SIGILOSO

Apêndice A. Comparabilidade com o ciclo anterior (iGovTI 2023 vs. iGovTI 2026)

A estrutura de 2026 preservou a escala de 0 a 1, as categorias de resposta e as quatro faixas de maturidade empregadas em 2023, mas alterou de forma relevante a composição dos agregados e seus pesos. As principais diferenças estão sintetizadas na Tabela 9.

Tabela 9 - Principais diferenças entre as estruturas do iGovTI 2023 e do iGovTI 2026

Aspecto	iGovTI 2023	iGovTI 2026	Implicação analítica
Composição do índice final	Governança de TIC e Gestão de TIC com pesos iguais de 0,50.	Governança de TIC com peso 0,4777 e Gestão de TIC com peso 0,5223.	A gestão passou a ter participação ligeiramente superior no índice final.
Governança de TIC	Agregação hierárquica de ModeloTI, MonitorAvaliaTI e ResultadoTI.	Agregação direta de quatro práticas relativas ao modelo de gestão, monitoramento, auditoria interna e simplificação de serviços públicos.	O componente tornou-se mais direto e incorporou práticas com escopo distinto da estrutura anterior.
Gestão de TIC	Agregação de Planejamento de TIC, Pessoas e Processos de TIC; este último reunia serviços, níveis de serviço, riscos, segurança, software, projetos e contratos.	Agregação direta das seis dimensões de Gestão de TIC descritas neste relatório.	O índice passou a evidenciar separadamente seis capacidades operacionais e de segurança.
Pessoas e contratações	Pessoas e contratações de TIC integravam o cálculo da Gestão de TIC.	Não integram a árvore de cálculo do iGovTI 2026, embora continuem relevantes para o diagnóstico e para a auditoria.	Mudanças nessas matérias não explicam diretamente a variação do índice de 2026.
Serviços, software e projetos	Serviços e níveis de serviço eram agregados distintos; software e projetos integravam Processos de TIC.	Serviços foram consolidados na dimensão Gestão de Serviços de TIC; software e projetos foram reunidos na dimensão Gestão de Soluções de TIC.	A leitura deve considerar a nova delimitação conceitual dos componentes.

(Fonte: elaboração própria)

Em razão dessas alterações, a diferença entre os valores nominais de 2023 e 2026 não deve ser interpretada automaticamente como evolução ou retrocesso institucional. Uma análise temporal válida exige a harmonização das questões e dos agregados comparáveis, além da consideração de mudanças de escopo, pesos, respondentes e qualidade das evidências.

Para viabilizar a análise longitudinal, foram elaboradas estruturas ajustadas comparáveis para 2023 e 2026, com a manutenção apenas das práticas passíveis de correspondência entre os instrumentos e a aplicação de uma estrutura comum de agregação. Após a normalização das siglas e a validação das correspondências institucionais, foram identificadas 69 organizações presentes nos dois ciclos, equivalentes a 60,5% das organizações com respostas completas em 2026. A comparação individual foi apresentada somente para esse conjunto pareado.

Os resultados ajustados comparáveis têm finalidade exclusivamente analítica. Eles não substituem os índices oficiais de cada ciclo, não eliminam integralmente os efeitos de alterações de respondentes ou de contexto institucional e não constituem, isoladamente, evidência de conformidade ou de inconformidade.

Apêndice B. Ajustes nas respostas declaradas

A Equipe de Auditoria, em busca da melhor representação do cenário atual de governança e gestão de TIC, ajustou resposta(s) declarada(s) pela organização **CEDAE** ao questionário iGovTI 2026.

Para tanto, foram utilizadas as justificativas e evidências fornecidas pelo jurisdicionado quando do envio das respostas ao questionário. Ressalta-se que a verificação dessa documentação foi realizada nos termos dos procedimentos definidos para a fiscalização, de modo que nem todas as evidências encaminhadas foram, necessariamente, objeto de análise exaustiva pela Equipe de Auditoria.

Seguem as alterações realizadas após a avaliação das respostas e da amostra de evidências, bem como as justificativas apresentadas pela Equipe:

Tabela 10 - Relação de respostas ajustadas pela Equipe após validação

Questão	Resposta original	Resposta ajustada	Justificativa
q1001	Adota parcialmente.	Não adota.	A organização apresentou o documento 'Plano Estratégico e Diretor de Tecnologia da Informação e Comunicação (PEDTIC) 2026-2029', contendo a estrutura do modelo de gestão. Entretanto, a capa do arquivo (página 5) apresenta a situação 'EM APROVAÇÃO', o que indica que o plano ainda não foi formalmente instituído pela alta administração. A ausência de um ato de aprovação torna a evidência insuficiente para considerar o modelo estabelecido. É necessária a apresentação do ato formal ou despacho de aprovação da alta gestão.
q1001ext[I]	Sim	Não	A evidência fornecida não é suficiente para comprovar a efetiva divulgação dos objetivos, indicadores e metas. O documento na página 4 contém apenas uma declaração de que a divulgação ocorre no site institucional, sem apresentar registros, capturas de tela ou links verificáveis que comprovem que tais informações estão, de fato, publicadas e acessíveis. É necessária a apresentação de comprovação material da divulgação externa ou interna dos indicadores e metas.

Questão	Resposta original	Resposta ajustada	Justificativa
q2201	Adota parcialmente.	Não adota.	A organização adota a prática de forma parcial. A evidência apresentada (arquivo 00102_08_evidências-2201.pdf) demonstra a existência de um catálogo de serviços estruturado no sistema GLPI, conforme listagem detalhada nas páginas 2 a 11 do documento. Todavia, a evidência é insuficiente para comprovar o monitoramento de níveis de serviço, visto que não foram apresentados elementos que demonstrem a gestão de desempenho. Identifica-se a ausência de Acordos de Nível de Serviço (ANS) formalizados, relatórios de indicadores de disponibilidade ou registros de acompanhamento de metas.
q2203	Adota parcialmente.	Não adota.	O item é considerado não conforme, pois a evidência apresentada limita-se a uma tela de monitoramento de ativos de rede no sistema Zabbix. Tal registro constitui ferramenta de acompanhamento operacional e não supre a necessidade de evidenciar a existência de um processo formal de gestão de configuração e ativos, incluindo normas, manuais ou procedimentos. Verifica-se a ausência de documentação sobre a governança do processo e responsabilidades, além da falta de abrangência da gestão sobre os demais ativos e serviços de tecnologia da informação.
q2203ext[A]	Sim	Não	O item é considerado não conforme, visto que a tela de monitoramento apresentada não caracteriza uma base de dados de configuração (CMDB) consolidada. A evidência demonstra apenas uma listagem técnica de roteadores com endereços IP e status, sem detalhar as configurações dos serviços de TI e os relacionamentos entre os ativos e as entregas de valor. Constata-se a ausência de uma base de dados que integre ativos e serviços de negócio, inviabilizando a comprovação do requisito de relacionamento.
q2204ext[C]	Sim	Não	A avaliação realizada indica que a evidência é insuficiente para comprovar o requisito. O material apresentado limita-se a registros de incidentes individuais, sem demonstrar a existência de uma base de conhecimento estruturada ou repositório de erros conhecidos para apoiar a resolução de demandas de forma eficiente. A ausência de elementos que atestem a presença de artigos, soluções mapeadas ou procedimentos reutilizáveis configura a inconformidade. Requer-se a apresentação de evidência de um repositório de conhecimento consultável.

Questão	Resposta original	Resposta ajustada	Justificativa
q2204ext[D]	Sim	Não	A avaliação realizada indica que não há evidências da formalização do processo de gestão de incidentes. O pacote de evidências restringe-se a capturas de tela de uma ferramenta de tecnologia, sem a apresentação de norma, política, guia ou procedimento institucional que defina as diretrizes do processo e as responsabilidades dos envolvidos. A falta de um documento formal de normatização constitui a lacuna que impede a conformidade. É necessário apresentar o documento ou ato institucional que estabeleça o processo.
q2501	Adota parcialmente.	Não adota.	A evidência apresentada é insuficiente para comprovar a execução do processo de gestão de ativos associados à informação. O documento consiste exclusivamente em uma captura de tela de ferramenta de monitoramento técnico de redes, sem demonstrar inventário formal, gestão de responsabilidades ou planos de proteção da informação. A avaliação realizada indica que o monitoramento operacional de dispositivos não se confunde com a gestão estratégica de ativos. Falta a apresentação de documentos normativos ou registros que evidenciem o processo de gestão em questão.
q2501ext[A]	Sim	Não	A evidência apresentada não configura inventário de ativos associados à informação, limitando-se a uma listagem de dispositivos de rede em ferramenta de monitoramento. O registro carece de atributos essenciais de gestão, tais como descrição detalhada, classificação ou vinculação a ativos de informação. Falta a apresentação de inventário formal estruturado que contemple a totalidade dos ativos associados à informação da organização.
q2501ext[B]	Sim	Não	O documento apresentado não contém informações sobre a definição de responsabilidades pelos ativos listados. Não foram identificados registros de papéis, atribuições ou proprietários dos dispositivos monitorados na evidência. Falta a apresentação de matriz de responsabilidades ou documento equivalente que demonstre a gestão dos ativos associados à informação.
q2501ext[C]	Sim	Não	A evidência não apresenta qualquer identificação ou classificação de criticidade das informações que os ativos armazenam, processam ou transmitem. A listagem fornecida restringe-se a dados técnicos operacionais, sem vínculos com a relevância das informações tratadas. Falta a comprovação de que o inventário considera a criticidade dos ativos para a organização.

Questão	Resposta original	Resposta ajustada	Justificativa
q2501ext[D]	Sim	Não	O monitoramento técnico de disponibilidade, conforme ilustrado no documento, não constitui, por si só, um processo de gestão que subsidie a implantação de controles de proteção. Não há evidência de que o processo de gestão alimente a definição ou implementação de ações de segurança para a proteção da informação. Falta a demonstração da relação entre a gestão de ativos e a aplicação efetiva de controles de proteção.
q2704	Adota parcialmente.	Não adota.	A prática não se encontra totalmente conforme. A evidência apresentada (Ordem de Serviço PR/ADM nº 16.067-02) institui rigorosos procedimentos de avaliação de integridade e compliance para nomeações em cargos de comissão e funções de confiança. Contudo, não foram encontrados nos documentos os perfis profissionais, competências técnicas ou requisitos de formação previamente definidos para os gestores de tecnologia da informação e segurança da informação. A evidência é insuficiente para atestar o atendimento integral ao requisito, devido à ausência de definição documentada das qualificações técnicas exigidas para tais posições.
q2706ext[C]	Sim	Não	Não há evidências que demonstrem o monitoramento da participação efetiva nas ações de capacitação listadas. O documento de planejamento apenas relaciona os participantes designados previamente, sem comprovação documental de frequência, relatórios de conclusão ou certificados de participação (páginas 1 a 6). A ausência de registros de presença ou indicadores de resultados das ações configura lacuna relevante.
q2706ext[D]	Sim	Não	A organização não apresentou evidências de análise periódica e crítica do plano de capacitação. Não constam nos autos atas de reunião, relatórios de revisão, indicadores de eficácia do plano ou registros de ajustes realizados em função de resultados anteriores. A ausência total de documentação sobre esse processo de revisão inviabiliza a conclusão de conformidade para este requisito.
q2708[C]	Sim	Não	A avaliação indica não conformidade. Embora a estrutura organizacional contemple a segurança da informação, o Edital de Seleção Pública (pág. 56) elenca apenas cargos de Engenheiro e Técnico de Segurança do Trabalho, que se referem à segurança ocupacional, e não à segurança da informação. Há ausência de cargo efetivo ou de provimento específico para Segurança da Informação no quadro de pessoal.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801	Adota em maior parte ou totalmente.	Não adota.	A evidência apresentada demonstra a existência de procedimentos e artefatos de contratação aplicáveis ao âmbito geral da organização. Não foram identificados processos de trabalho, fluxos ou artefatos estruturados especificamente para as particularidades das contratações de tecnologia da informação. A documentação torna-se insuficiente para comprovar a definição de processos voltados à TI, restando a lacuna de inexistência de normativos ou fluxos específicos para essa área.
q2801ext[A]	Sim	Não	Não há definição de um processo de trabalho voltado ao planejamento de contratações de TI, com delimitação de etapas e responsabilidades específicas. A documentação limita-se a modelos de contratação genéricos, carecendo de elementos que contemplem as especificidades do planejamento de soluções tecnológicas. Existe a lacuna de comprovação de um processo de planejamento estruturado para TI.
q2801ext[B]	Sim	Não	Os artefatos disponibilizados, como modelos de Termo de Referência e Matriz de Riscos, possuem caráter genérico e não abrangem as particularidades exigidas para o planejamento de soluções de TI. Ausência de artefatos específicos para a especificação de requisitos de tecnologia, como software e hardware. A documentação apresentada não supre a necessidade de modelos voltados para TI.
q2801ext[C]	Sim	Não	O processo de seleção de fornecedores apresentado refere-se a práticas gerais de licitação, não contemplando etapas ou procedimentos específicos para a seleção em TI. Não foram evidenciados fluxos que considerem as particularidades técnicas e de mercado deste setor. A evidência é considerada insuficiente por ausência de um processo focado em TI.
q2801ext[D]	Sim	Não	Embora existam modelos de editais e listas de verificação de habilitação genéricos, não foram apresentados artefatos de seleção contendo critérios de julgamento ou requisitos técnicos específicos para TI. A evidência é insuficiente por tratar apenas de contratações de caráter geral, sem artefatos voltados para contratações de tecnologia.
q2801ext[E]	Sim	Não	Não foram identificados fluxos de trabalho ou manuais de gestão e fiscalização de contratos voltados especificamente à área de tecnologia da informação. A ausência de definição de responsabilidades e artefatos de controle para esta área caracteriza a insuficiência da evidência apresentada.

Questão	Resposta original	Resposta ajustada	Justificativa
q2801ext[F]	Sim	Não	Os artefatos de gestão e fiscalização apresentados são de uso comum, inexistindo modelos voltados às particularidades de TI, como medição de níveis de serviço (SLAs) ou relatórios de desempenho de software. A evidência carece de documentos específicos para a fiscalização de contratos tecnológicos, tornando-a insuficiente.
q2801ext[G]	Sim	Não	A ausência de processos de trabalho e artefatos específicos para TI impede a verificação da aderência a normas legais e infralegais que regem as contratações de tecnologia. A conformidade não pôde ser atestada devido à falta de documentos direcionados às especificidades do setor de TI, configurando a evidência como insuficiente.
q2302ext[C]	Sim	Não	Não foi comprovada a existência de um gestor formalmente responsável por coordenar especificamente a gestão de riscos de segurança da informação. A Política de Gestão de Riscos apresenta atribuições genéricas para unidades organizacionais, e o PEDTIC aponta apenas a área 'DFI - TI' como responsável na tabela de riscos, sem designar uma pessoa física ou função específica para essa coordenação. Falta documento formal de designação que especifique a responsabilidade pela gestão de riscos de segurança da informação.
q2302ext[D]	Sim	Não	O processo de gestão de riscos de segurança da informação não está formalizado por meio de instrumento específico. A Política de Gestão de Riscos (PI-GC-0002) é um documento de abrangência corporativa geral, e o PEDTIC é um instrumento de planejamento estratégico, não estabelecendo diretrizes, fluxos operacionais ou responsabilidades exclusivas para a gestão de riscos de segurança da informação. Falta norma, guia ou documento interno dedicado e específico ao tema de segurança da informação.
q2404ext[F]	Sim	Não	O item não foi comprovado. Não foram apresentados processos, fluxogramas ou registros que demonstrem a efetiva comunicação de incidentes a partes interessadas ou a existência de critérios pré-definidos para essa atividade. A evidência limita-se a indicadores técnicos internos e não supre a necessidade de demonstrar a comunicação estruturada.
q2404ext[G]	Sim	Não	O item não foi comprovado. O pacote de evidências não contém relatórios de lições aprendidas, atas de reunião de pós-incidente ou documentos que demonstrem a análise de causa raiz e a implementação de melhorias. A existência de uma capa de relatório não substitui o conteúdo técnico necessário para evidenciar a análise pós-incidente.

Questão	Resposta original	Resposta ajustada	Justificativa
q2601	Adota em maior parte ou totalmente.	Não adota.	A Equipe de Auditoria avalia que a organização não comprovou a execução de um processo formal de software. A Política de Segurança da Informação enviada estabelece diretrizes gerais, mas não constitui normativo ou registro que demonstre a operacionalização de um ciclo de vida de desenvolvimento ou aquisição. A evidência é insuficiente, visto que não apresenta metodologias, requisitos ou indicadores de qualidade. Há lacuna na ausência de documentação formal do processo de software e registros que comprovem a sua prática na organização.
q2601ext[A]	Sim	Não	A Equipe de Auditoria avalia que a evidência não aborda a composição das equipes de desenvolvimento ou aquisição de software. O documento apresentado não contém diretrizes ou procedimentos que assegurem a participação de representantes da área de negócio, desde a concepção até a aceitação final. A suficiência da evidência é nula, pois o normativo limita-se a tópicos de segurança da informação e não ao processo de desenvolvimento em si. Há lacuna na ausência de procedimento que estabeleça a obrigatoriedade da participação das áreas de negócio no desenvolvimento ou aquisição de sistemas.
q3003[B]	Sim	Não	A evidência apresentada é considerada não conforme, visto que consiste integralmente em material publicitário público e não comprova a contratação efetiva dos serviços pela organização. O documento carece de elementos probatórios essenciais, tais como contrato, nota fiscal, empenho ou registro administrativo que vincule a entidade ao provedor do serviço. A análise técnica indica que o material possui natureza genérica e informativa, sem identificar a organização auditada como parte contratante ou usuária. Identifica-se como lacuna a ausência de qualquer documento formal ou ato administrativo que comprove a existência de vínculo contratual ou aquisição de licenças.

(Fonte: elaboração própria)